MSM ACADEMY

SECTION 3

Annex A Information Security Controls

Aligned with ISO/IEC 27002:2022



3.0 Introduction
3.1–3.6 A.5 Organizational controls (37)
3.7 A.6 People controls (8)
3.8–3.9 A.7 Physical controls (14)
3.10–3.14 A.8 Technological controls (34)
3.15 Section close

MSM ACADEMY

SECTION 3 · LESSON 3.0

Introduction to Annex A

3.0

How the controls fit the ISMS, and how this section teaches them.

LESSON 3.0

Annex A in the ISMS

How Annex A is used (ISO/IEC 27001, 6.1.3)

b) The organization determines the controls its risk treatment needs, from any source.

c) It compares them with Annex A to verify no necessary control is omitted.

d) The Statement of Applicability records the necessary controls, why they are included, whether they are implemented, and why any Annex A control is excluded.

- Annex A is normative, but it is a reference list: controls are selected by risk, not adopted wholesale.

LESSON 3.0

Four themes, 93 controls

Theme	Controls	Covers
A.5 Organizational	37	Policies, roles, assets, access, suppliers, incidents, continuity, compliance
A.6 People	8	Screening, employment terms, awareness, discipline, remote working, reporting
A.7 Physical	14	Perimeters, entry, offices, monitoring, equipment, media, utilities, cabling
A.8 Technological	34	Endpoints, access, malware, vulnerabilities, logging, networks, development, testing

LESSON 3.0

The 11 controls introduced in 2022

Control	Title
5.7	Threat intelligence
5.23	Information security for use of cloud services
5.30	ICT readiness for business continuity
7.4	Physical security monitoring
8.9	Configuration management
8.10	Information deletion
8.11	Data masking
8.12	Data leakage prevention
8.16	Monitoring activities
8.23	Web filtering
8.28	Secure coding

LESSON 3.0

ISO/IEC 27002:2022 and how it relates

For each control, ISO/IEC 27002 gives

1. The control: the same statement as Annex A.
2. Purpose: why the control exists.
3. Guidance: how it can be implemented.
4. Other information: context, related standards, variations.
5. Attributes: a classification for filtering and mapping.

ISO/IEC 27002 is guidance. Only ISO/IEC 27001 contains requirements.

LESSON 3.0

Five attribute categories

Attribute	Values
Control type	Preventive, Detective, Corrective
Information security properties	Confidentiality, Integrity, Availability
Cybersecurity concepts	Identify, Protect, Detect, Respond, Recover
Operational capabilities	15 values, e.g. Governance, Asset management, Identity and access management
Security domains	Governance and Ecosystem, Protection, Defence, Resilience

LESSON 3.0

Using attributes

What attributes are, and are not

- A classification and navigation aid: filter, sort and map controls to other frameworks.
- Not requirements: no clause of ISO/IEC 27001 requires a control to have a given attribute.
- Organizations can add their own attributes, for example ownership or cost.

How each control is taught

For every one of the 93 controls

1. The control, its purpose and its attributes.
2. What it means, and implementation guidance.
3. A practical example and the typical evidence.
4. The implementer’s and the auditor’s view, common difficulties and connections.

Simpler controls take fewer slides; complex ones get more guidance. Every control is taught individually.

LESSON 3.0 · KNOWLEDGE CHECK

Check your understanding

An organization adopts all 93 Annex A controls “to be safe”, without linking them to its risk assessment.

A Best practice: adopting every control removes the need for a risk assessment

B Acceptable: Annex A is a list to implement in full

C Weak: controls should follow from risk treatment, with Annex A as a check

D Required: ISO/IEC 27001 mandates all 93 controls

Check your understanding

An organization adopts all 93 Annex A controls “to be safe”, without linking them to its risk assessment.

A. Best practice: adopting every control removes the need for a risk assessment

B. Acceptable: Annex A is a list to implement in full

C. Weak: controls should follow from risk treatment, with Annex A as a check

D. Required: ISO/IEC 27001 mandates all 93 controls

Answer: C

6.1.3 requires controls to be determined from risk treatment and then compared with Annex A. Adopting all 93 skips that logic.

MSM ACADEMY

SECTION 3 · LESSON 3.1

A.5 Governance and roles

3.1

Controls 5.1–5.8: policies, roles, duties, management, outside contacts, threat intelligence and projects.

MSM ACADEMY

S3.2.1 · A.5 ORGANIZATIONAL CONTROLS

A.5.1 Policies for information security

5.1

Annex A control

S3.2.1 · CONTROL 5.1

5.1 Policies for information security

What the control asks

Define an information security policy and topic-specific policies; have them approved by management, published, communicated to and acknowledged by relevant people, and reviewed at planned intervals and when significant changes occur.

Purpose

Keep management’s direction and support for information security suitable, adequate and effective, in line with business, legal, regulatory and contractual requirements.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify

Operational capabilities
Governance

Security domains
Governance and Ecosystem · Resilience

5.1 What it means

- One top-level policy (the one required by ISO/IEC 27001, 5.2), with topic-specific policies beneath it.
- Topic policies cover areas such as access control, backup, cryptography, supplier security, secure development.
- Each policy has an owner, an approval, a review cycle and a target audience.
- Topic policies must be consistent with, and never contradict, the top-level policy.

5.1 Implementation guidance

- Top-level policy: objectives or their framework, principles, commitment to requirements and improvement, responsibilities, exceptions handling.
- Topic policies approved by the appropriate level of management, written for their audience.
- Communicate through onboarding, the intranet and training; obtain acknowledgement where it matters.
- Review at planned intervals and after changes: new laws, incidents, technology, organization.
- Keep the policy set under document control (7.5), with change history.

5.1 In practice

Logistics

The situation

- A logistics firm has one long policy written by IT five years ago
- Drivers and warehouse staff have never seen it

Applying the control

- A short top-level policy approved by the board
- Six topic policies, each with an owner
- Policies summarized for drivers in their mobile app, with acknowledgement

Typical evidence

- Approved policy set with versions
- Owners and review dates
- Acknowledgement records
- Change history after reviews

5.1 Two perspectives and common difficulties

Implementer's view

- Keep the top-level policy short; put detail in topic policies
- Give every policy an owner and a review date
- Plan how each policy reaches its audience

Auditor's view

- Approval at the right level
- Proof policies reached the people concerned
- Reviews actually performed, not just scheduled

Common difficulties

- Policies copied from templates
- No review since publication
- Topic policies that contradict each other or practice

Connections: ISO/IEC 27001 5.2 (policy) and 7.5 (documented information); 5.37 documented operating procedures; 6.3 awareness.

MSM ACADEMY

S3.2.2 · A.5 ORGANIZATIONAL CONTROLS

A.5.2 Information security roles and responsibilities

5.2

Annex A control

5.2 Information security roles and responsibilities

What the control asks

Define and allocate information security roles and responsibilities according to the organization’s needs.

Purpose

Establish a defined, approved and understood structure for implementing, operating and managing information security.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify

Operational capabilities
Governance

Security domains
Governance and Ecosystem · Protection · Resilience

5.2 What it means

- Responsibilities for protecting information and assets, and for security processes, are assigned to named roles.
- Typical roles: ISMS manager, asset and risk owners, system administrators, incident coordinators.
- Responsibilities can be delegated, but accountability stays with the assigning role.
- Roles are documented and communicated so people know what they own.

5.2 Implementation guidance

- Assign owners for each information asset and each risk.
- Define security responsibilities within job roles, including for contractors.
- Give each role the competence and authority it needs.
- Coordinate security across the organization, for example through a security forum.
- Review roles when the organization or its activities change.

5.2 In practice

Hospital

The situation

- Clinical system access is granted by whoever is on duty
- Nobody owns the patient-records risk

Applying the control

- Named owners for each clinical system
- A security lead per department, coordinated by a forum
- Responsibilities written into job descriptions

Typical evidence

- Roles and responsibilities document
- Asset and risk owners in registers
- Job descriptions with security duties
- Forum minutes

5.2 Two perspectives and common difficulties

Implementer's view

- Map every key asset and risk to an owner
- Write security duties into job roles
- Match responsibility with authority

Auditor's view

- Can role holders describe their duties?
- Do registers name owners who exist?
- Are gaps left by leavers filled?

Common difficulties

- Everything assigned to the IT department
- Owners named who have left
- Roles on paper that people do not know they hold

Connections: ISO/IEC 27001 5.3; 5.3 segregation of duties; 5.9 asset owners; 6.2 terms of employment.

MSM ACADEMY

S3.2.3 · A.5 ORGANIZATIONAL CONTROLS

A.5.3 Segregation of duties

Annex A control



5.3 Segregation of duties

What the control asks

Segregate conflicting duties and conflicting areas of responsibility.

Purpose

Reduce the risk of fraud, error and bypassing of information security controls.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Governance · Identity and access management

Security domains
Governance and Ecosystem

5.3 What it means

- Identify duties that conflict: requesting, approving and implementing the same change or access.
- Split them between different people, or between people and automated controls.
- Where staff numbers make full separation impossible, use compensating controls.
- Watch for collusion risk; segregation is strongest with monitoring.

5.3 Implementation guidance

- Typical conflicts: initiate vs approve vs execute; design vs implement; use vs administer; develop vs deploy to production.
- Build segregation into role design and access rights.
- Check segregation when granting access (5.18) and in periodic reviews.
- Document compensating controls where full segregation is not practical.

5.3 In practice

Financial services

The situation

- One payments officer can create, approve and release supplier payments
- Two-person team on night shift

Applying the control

- Create and approve split between roles in the payment system
- Night-shift releases above a limit need a second approver on call
- Daily review of released payments

Typical evidence

- Role matrix showing conflicts
- Payment system role settings
- Logs of dual approval
- Compensating-control description

5.3 Two perspectives and common difficulties

Implementer's view

- Identify conflicting duties per process
- Enforce splits in system roles, not only on paper
- Document compensating controls

Auditor's view

- Can any one person do and approve the same action?
- Do system roles match the role matrix?
- Are compensating controls actually performed?

Common difficulties

- Administrators with business approval rights
- Small teams with no compensating controls
- Emergency access that becomes permanent

Connections: 5.15 access control; 5.18 access rights; 8.2 privileged access rights; 8.32 change management.

MSM ACADEMY

S3.2.4 · A.5 ORGANIZATIONAL CONTROLS

A.5.4 Management responsibilities

Annex A control

5.4

S3.2.4 · CONTROL 5.4

5.4 Management responsibilities

What the control asks

Management requires all personnel to apply information security in line with the established policy, topic-specific policies and procedures.

Purpose

Ensure management understands its role in information security and acts so that all personnel are aware of and fulfil their responsibilities.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify

Operational capabilities
Governance

Security domains
Governance and Ecosystem

5.4 What it means

- Line managers, not only top management, actively support security.
- They brief their teams, set expectations and lead by example.
- They make sure people are trained, aware and resourced before accessing information.
- They treat security behaviour as part of normal performance management.

5.4 Implementation guidance

- Brief personnel on their security roles before granting access.
- Provide guidelines on security expectations for each role.
- Make sure people achieve the awareness and competence their role needs.
- Provide a confidential channel for reporting violations (whistleblowing).
- Allocate resources for security processes and projects.

5.4 In practice

Retail

The situation

- Store managers see security as head office’s job
- New staff use shared tills logins from day one

Applying the control

- Managers brief each new starter before access
- Shared logins removed; issues raised in team meetings
- Security behaviour included in staff reviews

Typical evidence

- Onboarding briefing records
- Team meeting notes
- Staff review criteria
- Confidential reporting channel

5.4 Two perspectives and common difficulties

Implementer's view

- Give managers a short briefing checklist
- Make access depend on the briefing being done
- Include security in performance reviews

Auditor's view

- Interview line managers, not just the ISMS team
- Do starters get briefed before access?
- Is the reporting channel known?

Common difficulties

- Managers unaware of their security role
- Access granted before briefing
- No safe way to report violations

Connections: ISO/IEC 27001 5.1 (leadership); 6.3 awareness; 6.4 disciplinary process; 6.8 event reporting.

MSM ACADEMY

S3.2.5 · A.5 ORGANIZATIONAL CONTROLS

A.5.5 Contact with authorities

Annex A control

5.5

5.5 Contact with authorities

What the control asks

Establish and maintain contact with relevant authorities.

Purpose

Ensure appropriate information flow about information security between the organization and legal, regulatory and supervisory authorities.

ISO/IEC 27002 attributes

Control type

Preventive · Corrective

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Identify · Protect · Respond · Recover

Operational capabilities

Governance

Security domains

Defence · Resilience

5.5 What it means and how it is done

- Know which authorities matter: regulators, data protection authority, law enforcement, national CERT, emergency services.
- Know who contacts them, when and how, especially during incidents.
- Keep the contact details and reporting obligations current.
- Use these contacts to anticipate changes in laws and regulations.

5.5 In practice

Energy

The situation

- An energy distributor must report serious cyber incidents within strict deadlines
- The incident plan lists outdated contacts

Applying the control

- Contact list of authorities with reporting triggers and deadlines
- Named people authorized to make contact
- Reviewed twice a year and after incidents

Typical evidence

- Current authorities contact list
- Reporting obligations register
- Records of past notifications

5.5 Two perspectives and common difficulties

Implementer's view

- List authorities with triggers, deadlines and authorized contacts
- Link the list to the incident procedure
- Review it regularly

Auditor's view

- Are contacts current?
- Do staff know who may contact an authority?
- Were past notifications made on time?

Common difficulties

- Contact lists out of date
- No one authorized to speak to regulators
- Reporting deadlines unknown until an incident

Connections: 5.24–5.26 incident management; 5.29 continuity; 5.31 legal and regulatory requirements; 5.6 special interest groups.

MSM ACADEMY

S3.2.6 · A.5 ORGANIZATIONAL CONTROLS

A.5.6 Contact with special interest groups

Annex A control



5.6 Contact with special interest groups

What the control asks

Establish and maintain contact with special interest groups or other specialist security forums and professional associations.

Purpose

Ensure appropriate information flow about information security with these groups.

ISO/IEC 27002 attributes

Control type
Preventive · Corrective

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect · Respond · Recover

Operational capabilities
Governance

Security domains
Defence

5.6 What it means and how it is done

- Examples: sector information-sharing groups, professional associations, vendor security communities.
- Benefits: early warnings, advice, best practice, contacts during incidents.
- Agree what may be shared; protect confidential information.
- Feed useful intelligence into risk assessment and threat intelligence (5.7).

5.6 In practice

Banking

The situation

A regional bank learns about attacks on peers only from the news

Applying the control

- Joins the banking sector information-sharing group
- Security lead attends monthly briefings
- Alerts reviewed and fed into vulnerability and threat processes

Typical evidence

- Membership records
- Briefing notes and alerts received
- Actions taken from shared intelligence

5.6 Two perspectives and common difficulties

Implementer's view

- Choose groups relevant to the sector and technology
- Set rules on what may be shared
- Route what is learned into risk and threat processes

Auditor's view

- Which groups, and why these?
- Is anything learned actually used?
- Are sharing rules respected?

Common difficulties

- Membership with no follow-up
- Sharing confidential details carelessly
- Information received but never acted on

Connections: 5.7 threat intelligence; 5.5 authorities; 8.8 technical vulnerabilities; 6.3 awareness.

MSM ACADEMY

S3.2.7 · A.5 ORGANIZATIONAL CONTROLS

A.5.7 Threat intelligence

Annex A control · New in 2022

5.7

S3.2.7 · CONTROL 5.7

NEW IN 2022

5.7 Threat intelligence

What the control asks

Collect and analyse information relating to information security threats to produce threat intelligence.

Purpose

Provide awareness of the organization’s threat environment so that appropriate mitigation actions can be taken.

ISO/IEC 27002 attributes

Control type

Preventive · Detective · Corrective

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Identify · Detect · Respond

Operational capabilities

Threat and vulnerability management

Security domains

Defence · Resilience

5.7 What it means

- Three levels: strategic (high-level trends), tactical (attacker methods), operational (specific attacks and indicators).
- Intelligence should be relevant, insightful, contextual and actionable.
- Sources: internal (logs, incidents) and external (vendors, CERTs, sector groups).
- The goal is decisions and actions, not a collection of feeds.

5.7 Implementation guidance (1 of 2)

- Set objectives: what decisions should intelligence support?
- Identify, vet and select internal and external sources.
- Collect, then process: organize, translate, deduplicate.
- Analyse for relevance to the organization’s assets and risks.

5.7 Implementation guidance (2 of 2)

- Communicate results to the people who can act, in a usable form.
- Feed intelligence into risk assessment, controls (e.g. firewall, detection rules) and testing.
- Share intelligence with others where agreed.
- Review whether intelligence actually changed decisions.

5.7 In practice

Manufacturing

The situation

- A manufacturer receives many vendor alerts but nobody reads them
- A ransomware group is targeting its sector

Applying the control

- Monthly intelligence summary for IT and management
- Indicators loaded into detection tools
- Risk assessment updated for the ransomware threat

Typical evidence

- Defined sources and objectives
- Intelligence reports
- Detection rule updates linked to intelligence
- Risk register changes

5.7 Two perspectives and common difficulties

Implementer's view

- Start from the decisions intelligence must support
- Keep sources few, vetted and relevant
- Close the loop into risk and detection

Auditor's view

- What intelligence led to what action?
- Are sources defined and reviewed?
- Does the risk assessment reflect current threats?

Common difficulties

- Subscribing to feeds without analysis
- Intelligence that never reaches decision-makers
- Confusing threat intelligence with vulnerability alerts

Connections: 5.6 special interest groups; ISO/IEC 27001 6.1.2 risk assessment; 8.8 vulnerabilities; 8.16 monitoring; 5.25 event assessment.

MSM ACADEMY

S3.2.8 · A.5 ORGANIZATIONAL CONTROLS

A.5.8 Information security in project management

5.8

Annex A control

S3.2.8 · CONTROL 5.8

5.8 Information security in project management

What the control asks

Integrate information security into project management.

Purpose

Ensure information security risks related to projects and deliverables are effectively addressed throughout the project life cycle.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify · Protect

Operational capabilities
Governance

Security domains
Governance and Ecosystem · Protection

5.8 What it means

- Applies to every type of project, not only IT: office moves, new services, outsourcing.
- Security risks are assessed early and at defined stages.
- Security requirements are identified and become part of the deliverables.
- Security is checked before go-live.

5.8 Implementation guidance

- Include a security risk assessment at project start and at key milestones.
- Define security requirements: information classification, legal needs, access, continuity.
- Assign security responsibility within the project.
- Include security checks in testing and acceptance.
- Hand over security operations and documentation at closure.

5.8 In practice

Public sector

The situation

- A council launches an online permit service
- Security was considered only after build

Applying the control

- Security risk assessment at the project gate
- Requirements for data protection and authentication
- Security testing before launch

Typical evidence

- Project gates with security criteria
- Project risk assessments
- Security requirements and test results

5.8 Two perspectives and common difficulties

Implementer's view

- Put security criteria into project gates
- Make a named person responsible for project security
- Require evidence before go-live

Auditor's view

- Pick a recent project: when were risks assessed?
- Were security requirements tested?
- Were exceptions approved?

Common difficulties

- Security added at the end
- Non-IT projects ignored
- Requirements written but never tested

Connections: 8.25–8.29 secure development and testing; ISO/IEC 27001 6.1 and 8.1; 5.23 cloud services; 8.32 change management.

Lesson 3.1 recap

- 5.1–5.2: policies and roles set direction and ownership
- 5.3–5.4: conflicting duties split; managers apply security in their teams
- 5.5–5.7: authorities, specialist groups and threat intelligence keep the organization informed
- 5.8: security built into every project

Check your understanding

A small company cannot separate payment creation and approval: only two people work in finance.

A 5.3 cannot be met, so it must be excluded in the SoA

B Hire a third person, or the control fails

C Use compensating controls such as monitoring and management review

D Segregation only applies to IT administrators

Check your understanding

A small company cannot separate payment creation and approval: only two people work in finance.

A. 5.3 cannot be met, so it must be excluded in the SoA

B. Hire a third person, or the control fails

C. **Use compensating controls such as monitoring and management review**

D. Segregation only applies to IT administrators

Answer: C

Where full segregation is not practical, compensating controls such as monitoring, audit trails and supervision manage the risk.

MSM ACADEMY

SECTION 3 · LESSON 3.2

A.5 Information and assets

3.2

Controls 5.9–5.14: inventory, acceptable use, return, classification, labelling and transfer.

MSM ACADEMY

S3.2.9 · A.5 ORGANIZATIONAL CONTROLS

A.5.9 Inventory of information and other associated assets

5.9

Annex A control

5.9 Inventory of information and other associated assets

What the control asks

Develop and maintain an inventory of information and other associated assets, including owners.

Purpose

Identify the organization’s information and other associated assets in order to preserve their information security and assign appropriate ownership.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify

Operational capabilities
Asset management

Security domains
Governance and Ecosystem · Protection

5.9 What it means

- Information comes first: databases, documents, records; then the assets that hold or process it.
- Associated assets: hardware, software, services, people and locations where relevant.
- Each entry has an owner responsible for its protection throughout its life cycle.
- The inventory is accurate, current, consistent and aligned with other inventories.

5.9 Implementation guidance

- Choose a practical level of detail, by risk.
- Record location, owner, classification and relevant dependencies.
- Keep the inventory current through joiner, change and disposal processes.
- Owners ensure assets are classified, protected, reviewed and properly disposed of.
- Inventories can be separate (e.g. IT, information), but must link.

5.9 In practice

Professional services

The situation

- A law firm knows its laptops but not where client files are stored
- Cloud shares created by individual lawyers

Applying the control

- Inventory of client information by type and location
- Each repository and cloud share has an owner
- New cloud shares registered through IT

Typical evidence

- Inventory with owners and classification
- Link to IT asset register
- Evidence of periodic review

5.9 Two perspectives and common difficulties

Implementer's view

- Start with information, then map supporting assets
- Assign real owners
- Connect the inventory to processes that change assets

Auditor's view

- Sample assets in use: are they in the inventory?
- Do owners know they own them?
- When was it last reviewed?

Common difficulties

- Hardware-only inventories
- Inventories created once for certification
- Shadow IT and cloud services missing

Connections: 5.10 acceptable use; 5.11 return of assets; 5.12 classification; 7.10 storage media; 8.1 endpoint devices.

MSM ACADEMY

S3.2.10 · A.5 ORGANIZATIONAL CONTROLS

A.5.10 Acceptable use of information and other associated assets

5.10

Annex A control

S3.2.10 · CONTROL 5.10

5.10 Acceptable use of information and other associated assets

What the control asks

Identify, document and implement rules for the acceptable use and procedures for handling information and other associated assets.

Purpose

Ensure information and other associated assets are appropriately protected, used and handled.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Asset management · Information protection

Security domains
Governance and Ecosystem · Protection

5.10 What it means

- Rules apply to staff and external users with access.
- They cover expected and unacceptable behaviour, and monitoring.
- Handling procedures follow the classification scheme (5.12).
- People must be made aware of the rules before use.

5.10 Implementation guidance

- Topic-specific policy on acceptable use, including personal use and monitoring.
- Handling procedures per classification level: access, storage, copying, transfer, disposal.
- Restrictions on removable media, personal cloud services and printing where needed.
- Records of authorized recipients for sensitive information.
- Acknowledgement of the rules by users.

5.10 In practice

Healthcare

The situation

Clinicians email patient letters to personal accounts to work at home

Applying the control

- Acceptable use policy bans personal accounts for patient data
- Handling rules for confidential data: approved systems only
- Secure remote access provided as the alternative

Typical evidence

- Acceptable use policy and acknowledgements
- Handling procedures by classification
- Email filtering or DLP alerts

5.10 Two perspectives and common difficulties

Implementer's view

- Write rules people can actually follow
- Tie handling rules to classification levels
- Offer secure alternatives to banned practices

Auditor's view

- Are rules acknowledged?
- Do handling practices match the classification?
- How are breaches of the rules detected?

Common difficulties

- Rules nobody has read
- Bans without alternatives, leading to workarounds
- Handling rules disconnected from classification

Connections: 5.12 classification; 5.13 labelling; 5.14 transfer; 6.2 terms of employment; 8.12 data leakage prevention.

MSM ACADEMY

S3.2.11 · A.5 ORGANIZATIONAL CONTROLS

A.5.11 Return of assets

Annex A control

5.11

S3.2.11 · CONTROL 5.11

5.11 Return of assets

What the control asks

Personnel and other interested parties return all the organization’s assets in their possession upon change or termination of their employment, contract or agreement.

Purpose

Protect the organization’s assets as part of the process of changing or terminating employment, contract or agreement.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Asset management

Security domains
Protection

5.11 What it means and how it is done

- Formal return process for leavers and role changes: devices, cards, keys, documents.
- Includes information on personal devices and knowledge to be transferred.
- Covers contractors and suppliers, not only employees.
- Access is removed in parallel (5.18).
- Unreturned assets are followed up and recorded.

5.11 In practice

Construction

The situation

- Site engineers leave with tablets holding project drawings
- Contractors keep site access cards

Applying the control

- Exit checklist driven by the asset inventory
- Information on personal devices wiped or returned
- Unreturned items escalated as incidents

Typical evidence

- Completed exit checklists
- Inventory updates on return
- Records of escalation for unreturned items

5.11 Two perspectives and common difficulties

Implementer's view

- Drive the exit checklist from the inventory
- Include contractors and role changes
- Coordinate with access removal

Auditor's view

- Sample recent leavers: were all assets returned?
- Were contractors included?
- How are missing items handled?

Common difficulties

- Returns depending on goodwill
- Role changes overlooked
- Data on personal devices forgotten

Connections: 5.9 inventory; 5.18 access rights; 6.5 responsibilities after termination; 8.10 information deletion.

MSM ACADEMY

S3.2.12 · A.5 ORGANIZATIONAL CONTROLS

A.5.12 Classification of information

5.12

Annex A control

S3.2.12 · CONTROL 5.12

5.12 Classification of information

What the control asks

Classify information according to the organization’s information security needs, based on confidentiality, integrity, availability and relevant interested party requirements.

Purpose

Ensure identification and understanding of the protection needs of information in accordance with its importance to the organization.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify

Operational capabilities
Information protection

Security domains
Protection · Defence

5.12 What it means

- A classification scheme defines levels and the criteria for each.
- Owners classify information; classification drives handling (5.10) and labelling (5.13).
- It can consider integrity and availability needs, not only confidentiality.
- Classification can change over time, for example when information is published.

5.12 Implementation guidance (1 of 2)

- Keep the scheme simple: few levels, clear criteria and examples.
- Base levels on the impact of compromise.
- Align with legal and contractual classifications, and with partners where information is shared.

5.12 Implementation guidance (2 of 2)

- Assign classification responsibility to information owners.
- Classify at creation, and review periodically or on change.
- Connect each level to handling, labelling, access and disposal rules.
- Train people to apply the scheme consistently.

5.12 In practice

Pharmaceuticals

The situation

Research data, regulatory submissions and marketing material all treated the same

Applying the control

- Four levels with examples per department
- Research data classified restricted by owners
- Each level linked to storage, sharing and disposal rules

Typical evidence

- Classification policy with criteria
- Classified repositories
- Training records
- Reviews of classifications

5.12 Two perspectives and common difficulties

Implementer's view

- Keep levels few and concrete
- Make owners responsible
- Link every level to handling rules

Auditor's view

- Is classification applied consistently?
- Do handling practices match the level?
- Are classifications reviewed?

Common difficulties

- Too many levels, so everything becomes confidential
- Classification with no effect on handling
- No owner deciding the level

Connections: 5.9 inventory; 5.10 handling; 5.13 labelling; 5.14 transfer; 8.3 access restriction; 8.12 data leakage prevention.

MSM ACADEMY

S3.2.13 · A.5 ORGANIZATIONAL CONTROLS

A.5.13 Labelling of information

5.13

Annex A control

S3.2.13 · CONTROL 5.13

5.13 Labelling of information

What the control asks

Develop and implement an appropriate set of procedures for information labelling in accordance with the organization’s classification scheme.

Purpose

Facilitate communication of the classification of information and support automation of information processing and management.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Information protection

Security domains
Defence · Protection

5.13 What it means and how it is done

- Labels make the classification visible: headers, watermarks, metadata, stickers.
- Procedures cover physical and electronic information, and exceptions.
- Metadata labels allow tools such as DLP to enforce handling rules.
- Some information need not be labelled, e.g. public; define this.
- People are trained to apply and respect labels.

5.13 In practice

Engineering

The situation

Drawings sent to suppliers carry no indication of sensitivity

Applying the control

- Confidential drawings get a footer and metadata label automatically
- Email gateway checks labels before external sending
- Supplier contracts reference the labels

Typical evidence

- Labelling procedure
- Labelled documents and metadata
- Gateway rule configuration

5.13 Two perspectives and common difficulties

Implementer's view

- Automate labels where possible
- Define where labels are not required
- Use metadata so tools can act

Auditor's view

- Do labels match classifications?
- Are labels used by tools or people?
- Are physical media labelled?

Common difficulties

- Manual labelling that is skipped
- Labels inconsistent with classification
- Labels ignored by recipients

Connections: 5.12 classification; 5.10 handling; 5.14 transfer; 8.12 data leakage prevention.

MSM ACADEMY

S3.2.14 · A.5 ORGANIZATIONAL CONTROLS

A.5.14 Information transfer

5.14

Annex A control

S3.2.14 · CONTROL 5.14

5.14 Information transfer

What the control asks

Have information transfer rules, procedures or agreements in place for all types of transfer facilities within the organization and between it and other parties.

Purpose

Maintain the security of information transferred within an organization and with any external interested party.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Asset management · Information protection

Security domains
Protection

5.14 What it means

- Three kinds of transfer: electronic (email, file transfer), physical media, verbal.
- Rules depend on classification: what may be sent, how, and to whom.
- External transfers are covered by agreements setting responsibilities.
- Protection in transit: encryption, integrity checks, trusted couriers.

5.14 Implementation guidance

- Electronic: approved channels, encryption for sensitive data, protection against interception and malware.
- Physical media: trusted couriers, tamper-evident packaging, logs of dispatch and receipt.
- Verbal: care in public places, phones and meetings; no sensitive data on voicemail.
- Agreements: responsibilities, notification, labelling, liability, chain of custody.

5.14 In practice

Architecture firm

The situation

Building plans are emailed to contractors as unencrypted attachments

Applying the control

- Secure file-sharing portal for all plans
- Transfer terms in each contractor agreement
- Email blocked for files labelled confidential

Typical evidence

- Transfer procedure and approved channels
- Signed agreements with transfer terms
- Portal and gateway logs

5.14 Two perspectives and common difficulties

Implementer's view

- Define approved channels by classification
- Make the secure route the easy route
- Cover regular external transfers by agreement

Auditor's view

- How is sensitive data actually sent?
- Do agreements exist for regular transfers?
- Is verbal disclosure addressed in training?

Common difficulties

- Unapproved channels used for convenience
- No agreements with regular recipients
- Verbal and physical transfer ignored

Connections: 5.12–5.13 classification and labelling; 8.24 cryptography; 8.12 data leakage prevention; 5.19–5.20 supplier agreements.

LESSON 3.2 · RECAP

Lesson 3.2 recap

- 5.9: an inventory of information and assets, with owners
- 5.10–5.11: acceptable use and handling rules; assets returned at exit
- 5.12–5.13: classification by need, made visible by labelling
- 5.14: transfer rules for electronic, physical and verbal transfer

Check your understanding

A company has a four-level classification scheme, but staff store “restricted” files on the same open share as everything else.

A Conforming: the scheme exists

B The gap is in handling rules: classification must drive how information is treated

C Only labelling (5.13) is missing

D Classification is optional when an inventory exists

Check your understanding

A company has a four-level classification scheme, but staff store “restricted” files on the same open share as everything else.

A. Conforming: the scheme exists

B. The gap is in handling rules: classification must drive how information is treated

C. Only labelling (5.13) is missing

D. Classification is optional when an inventory exists

Answer: B

Classification only protects information if it drives handling, access and storage rules (5.10, 5.12). Here it changes nothing.

MSM ACADEMY

SECTION 3 · LESSON 3.3

A.5 Identity and access

Controls 5.15–5.18: access control rules, identity management, authentication information and access rights.



MSM ACADEMY

S3.2.15 · A.5 ORGANIZATIONAL CONTROLS

A.5.15 Access control

Annex A control

5.15

S3.2.15 · CONTROL 5.15

5.15 Access control

What the control asks

Establish and implement rules to control physical and logical access to information and other associated assets based on business and information security requirements.

Purpose

Ensure authorized access and prevent unauthorized access to information and other associated assets.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Identity and access management

Security domains
Protection

5.15 What it means

- Access rules are set by asset owners, based on business need and classification.
- Two key principles: need-to-know and need-to-use; least privilege.
- Rules cover both logical (systems, data) and physical (buildings, rooms) access.
- Usually documented in a topic-specific access control policy.

5.15 Implementation guidance (1 of 2)

- Define who may access what, and under which conditions, per asset or role.
- Prefer role-based or attribute-based models over individual grants.
- Consider segregation of duties (5.3) and privileged access (8.2).
- Consider legal and contractual restrictions on access.

5.15 Implementation guidance (2 of 2)

- Define rules for authorizing, changing and removing access.
- Default stance: “everything is forbidden unless expressly permitted”.
- Cover access by suppliers, customers and other external parties.
- Keep logs of access events where needed; review rules regularly.

5.15 In practice

Insurance

The situation

Claims handlers can see every customer file in the company

Applying the control

- Role-based access: handlers see only claims in their region
- Fraud team given broader access with approval
- Access policy reviewed annually by data owners

Typical evidence

- Access control policy
- Role definitions and access matrix
- Approval records for exceptions

5.15 Two perspectives and common difficulties

Implementer's view

- Write the rules with asset owners
- Build roles around least privilege
- Default to deny

Auditor's view

- Do actual permissions match the rules?
- Who approved broad access, and why?
- Are physical and logical access both covered?

Common difficulties

- Rules written by IT without owners
- Roles that accumulate rights over time
- Physical access forgotten

Connections: 5.16 identity management; 5.17 authentication; 5.18 access rights; 8.2–8.3 privileged access and access restriction; 7.2 physical entry.

MSM ACADEMY

S3.2.16 · A.5 ORGANIZATIONAL CONTROLS

A.5.16 Identity management

Annex A control

5.16

S3.2.16 · CONTROL 5.16

5.16 Identity management

What the control asks

Manage the full life cycle of identities.

Purpose

Allow the unique identification of individuals and systems accessing information and other associated assets, and enable appropriate assignment of access rights.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Identity and access management

Security domains
Protection

5.16 What it means

- Every identity is linked to a single person, or to a system with an accountable owner.
- Shared identities only where necessary, approved and documented.
- Life cycle: registration, changes, disabling and removal.
- Identities of external parties and non-human accounts included.

5.16 Implementation guidance (1 of 2)

- Verify identity before registration (linked to HR or contract).
- Assign unique identifiers; avoid re-using them.
- Approve and document any shared identity and who uses it.
- Disable identities promptly when no longer needed.

5.16 Implementation guidance (2 of 2)

- Maintain records of significant events on identities.
- Manage identities of external users through their sponsor.
- Assign owners to service and system accounts.
- Use central identity management where practical.

5.16 In practice

University

The situation

- Thousands of student and visiting researcher accounts never disabled
- Lab instruments run on a shared admin account

Applying the control

- Accounts created from enrolment and HR systems, disabled automatically at exit
- Visiting researchers sponsored by a faculty member
- Lab accounts given named owners and individual logins

Typical evidence

- Identity life cycle procedure
- Automated feeds from HR and enrolment
- Sponsor confirmations
- Owner list for system accounts

5.16 Two perspectives and common difficulties

Implementer's view

- Drive identities from authoritative sources (HR, contracts)
- Eliminate or control shared accounts
- Own every non-human account

Auditor's view

- Do active identities match current people?
- Who owns each service account?
- Are shared accounts justified?

Common difficulties

- Orphaned accounts after leavers
- Shared admin accounts
- Service accounts nobody owns

Connections: 5.15 access rules; 5.17 authentication; 5.18 access rights; 6.5 termination; 8.5 secure authentication.

MSM ACADEMY

S3.2.17 · A.5 ORGANIZATIONAL CONTROLS

A.5.17 Authentication information

5.17

Annex A control

S3.2.17 · CONTROL 5.17

5.17 Authentication information

What the control asks

Control the allocation and management of authentication information through a management process, including advising personnel on appropriate handling.

Purpose

Ensure proper entity authentication and prevent failures of authentication processes.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Identity and access management

Security domains
Protection

5.17 What it means

- Secure allocation: initial secrets are unique, delivered securely and changed on first use.
- User responsibilities: keep secrets confidential, never share, report compromise.
- Password quality and management systems support good practice.
- Default vendor credentials are changed on installation.

5.17 Implementation guidance (1 of 2)

- Verify identity before issuing or resetting authentication information.
- Deliver initial or temporary secrets securely; force change on first use.
- Acknowledge receipt; store secrets only in protected form.
- Change default vendor passwords at installation.

5.17 Implementation guidance (2 of 2)

- Advise users: no sharing, no writing down, separate personal and work passwords.
- Prefer strong passphrases and multi-factor authentication.
- Change secrets on suspected compromise; screen against known-breached passwords.
- Use password managers; protect password files (hashing).

5.17 In practice

IT services

The situation

- Help desk resets passwords over the phone without verifying the caller
- New staff receive “Welcome1” as their first password

Applying the control

- Caller verification before any reset
- Unique temporary passwords sent securely, changed at first login
- MFA rolled out; breached-password screening enabled

Typical evidence

- Authentication information procedure
- Help desk verification records
- System settings for first-use change and screening

5.17 Two perspectives and common difficulties

Implementer's view

- Secure the reset process first
- Force change of initial secrets
- Give users practical guidance and tools

Auditor's view

- How does the help desk verify identity?
- Are default credentials removed?
- How are stored secrets protected?

Common difficulties

- Weak help-desk resets
- Shared or default credentials
- Passwords in spreadsheets or scripts

Connections: 5.16 identity; 5.18 access rights; 8.5 secure authentication; 8.24 cryptography; 6.3 awareness.

MSM ACADEMY

S3.2.18 · A.5 ORGANIZATIONAL CONTROLS

A.5.18 Access rights

Annex A control

5.18

S3.2.18 · CONTROL 5.18

5.18 Access rights

What the control asks

Provision, review, modify and remove access rights to information and other associated assets in accordance with the topic-specific policy and rules for access control.

Purpose

Ensure access to information and other associated assets is defined and authorized according to business requirements.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Identity and access management

Security domains
Protection

5.18 What it means

- Provisioning: authorized by the asset owner, checked against policy and segregation.
- Changes: rights updated on role change, not just added.
- Reviews: periodic, and after changes, by owners or managers.
- Removal: promptly at termination or when no longer needed.

5.18 Implementation guidance (1 of 2)

- Owner authorization before granting access; record of who approved what.
- Rights activated only after authorization; temporary access with an end date.
- Central record of rights granted to each identity.
- Contracts and terms state consequences of unauthorized access.

5.18 Implementation guidance (2 of 2)

- Review rights regularly; review privileged rights more often.
- Adjust rights immediately on role change; remove before or at termination.
- Consider removal before termination where the departure is contentious.
- Act on review findings and keep evidence of the review.

5.18 In practice

Hospital

The situation

- Agency nurses keep access to the patient system for months after their placement ends
- Access reviews are done but never acted on

Applying the control

- Placements carry an end date that disables access automatically
- Ward managers review access monthly; removals tracked
- Movers lose previous ward access when they transfer

Typical evidence

- Access requests and approvals
- Completed reviews with actions
- Leaver and mover reports matched to removals

5.18 Two perspectives and common difficulties

Implementer's view

- Link access to HR joiner, mover and leaver events
- Assign reviews to owners with deputies
- Track review findings to closure

Auditor's view

- Sample leavers: when was access removed?
- Sample movers: were old rights removed?
- Were reviews completed and acted on?

Common difficulties

- Rights accumulate on role changes
- Reviews rubber-stamped
- Reviews stop when a person leaves

Connections: 5.15 access rules; 5.16 identities; 5.3 segregation; 8.2 privileged access; 6.5 termination; 5.11 return of assets.

LESSON 3.3 · RECAP

Lesson 3.3 recap

- 5.15: access rules based on need-to-know, need-to-use and least privilege
- 5.16: every identity unique, owned and managed through its life cycle
- 5.17: authentication information issued, used and reset securely
- 5.18: access rights authorized, reviewed, changed and removed on time

Check your understanding

An employee moved from Finance to Marketing six months ago and can still approve payments.

A A 5.17 issue: her password should have been changed

B A 5.18 issue: rights must be modified when roles change

C Acceptable if she has not used the payment rights

D Only a problem if Finance raises an incident

Check your understanding

An employee moved from Finance to Marketing six months ago and can still approve payments.

A. A 5.17 issue: her password should have been changed

B. A 5.18 issue: rights must be modified when roles change

C. Acceptable if she has not used the payment rights

D. Only a problem if Finance raises an incident

Answer: B

5.18 requires access rights to be modified or removed when roles change. Unused rights are still a risk and still a gap.

MSM ACADEMY

SECTION 3 · LESSON 3.4

A.5 Suppliers and cloud

3.4

Controls 5.19–5.23: supplier relationships, agreements, the ICT supply chain, monitoring and cloud services.

MSM ACADEMY

S3.2.19 · A.5 ORGANIZATIONAL CONTROLS

A.5.19 Information security in supplier relationships

5.19

Annex A control

S3.2.19 · CONTROL 5.19

5.19 Information security in supplier relationships

What the control asks

Define and implement processes and procedures to manage the information security risks associated with the use of supplier’s products or services.

Purpose

Maintain an agreed level of information security in supplier relationships.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify

Operational capabilities
Supplier relationships security

Security domains
Governance and Ecosystem · Protection

5.19 What it means

- A topic-specific supplier security policy and process covers the whole relationship.
- Suppliers are identified and categorized by the information and access involved.
- Security is considered in selection, contracting, operation and exit.
- Covers all supplier types: cloud, IT, logistics, cleaning, consultants.

5.19 Implementation guidance (1 of 2)

- Identify and categorize suppliers by risk (information, access, criticality).
- Define security requirements per category.
- Evaluate suppliers before selection: questionnaires, certifications, audits.
- Define how suppliers access information and facilities, and monitor that access.

5.19 Implementation guidance (2 of 2)

- Handle incidents and contingencies involving suppliers.
- Train staff who manage suppliers.
- Manage supplier changes and the transition of information at exit.
- Keep the supplier list and categorization current.

5.19 In practice

Hotel group

The situation

- A hotel group uses dozens of suppliers, from booking engines to cleaning firms
- No one knows which ones handle guest data

Applying the control

- Supplier register with risk categories
- Security due diligence for high-risk suppliers
- Exit steps for return and deletion of guest data

Typical evidence

- Supplier security policy
- Categorized supplier register
- Due diligence records
- Exit checklists

5.19 Two perspectives and common difficulties

Implementer's view

- Categorize suppliers by risk first
- Scale due diligence to the category
- Plan exit from the start

Auditor's view

- Is the supplier list complete?
- What due diligence was done for a high-risk supplier?
- How are exits handled?

Common difficulties

- Only IT suppliers considered
- One-off checks at onboarding
- No exit plan for data

Connections: 5.20 agreements; 5.21 ICT supply chain; 5.22 monitoring; 5.23 cloud; ISO/IEC 27001 8.1 externally provided processes.

MSM ACADEMY

S3.2.20 · A.5 ORGANIZATIONAL CONTROLS

A.5.20 Addressing information security within supplier agreements

5.20

Annex A control

S3.2.20 · CONTROL 5.20

5.20 Addressing information security within supplier agreements

What the control asks

Establish and agree relevant information security requirements with each supplier based on the type of supplier relationship.

Purpose

Maintain an agreed level of information security in supplier relationships.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify

Operational capabilities
Supplier relationships security

Security domains
Governance and Ecosystem · Protection

5.20 What it means

- Requirements are written into agreements, proportionate to risk.
- Both parties understand their obligations.
- Agreements cover information, access, controls, incidents, audit rights and exit.
- Existing agreements are reviewed when requirements change.

5.20 Implementation guidance

- Describe the information, its classification and permitted use.
- Legal and regulatory requirements, including data protection and intellectual property.
- Required controls: access, encryption, personnel screening, sub-contracting rules.
- Incident notification times and cooperation.
- Right to audit, reporting, and return or destruction of information at termination.

5.20 In practice

Retail

The situation

An online retailer’s payment provider contract is silent on breach notification

Applying the control

- Security schedule added to all high-risk contracts
- 72-hour breach notification and audit rights agreed
- Data return and deletion at termination specified

Typical evidence

- Signed agreements with security clauses
- Contract register showing which suppliers have them
- Records of contract reviews

5.20 Two perspectives and common difficulties

Implementer's view

- Use a standard security schedule by supplier category
- Include notification, audit and exit clauses
- Track which contracts lack them

Auditor's view

- Do high-risk contracts contain the requirements?
- Are notification times defined?
- Is sub-contracting controlled?

Common difficulties

- Old contracts never updated
- Standard supplier terms accepted unchanged
- Requirements not matched to risk

Connections: 5.19 supplier policy; 5.21 ICT supply chain; 5.22 monitoring; 5.14 transfer; 5.34 privacy.

MSM ACADEMY

S3.2.21 · A.5 ORGANIZATIONAL CONTROLS

A.5.21 Managing information security in the ICT supply chain

5.21

Annex A control

S3.2.21 · CONTROL 5.21

5.21 Managing information security in the ICT supply chain

What the control asks

Define and implement processes and procedures to manage the information security risks associated with the ICT products and services supply chain.

Purpose

Maintain an agreed level of information security in supplier relationships.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify

Operational capabilities
Supplier relationships security

Security domains
Governance and Ecosystem · Protection

5.21 What it means

- ICT products and services depend on components and sub-suppliers.
- Security requirements flow down the chain.
- Risks include compromised components, counterfeit hardware, end-of-support software.
- Visibility of origin and support life of critical components matters.

5.21 Implementation guidance (1 of 2)

- Require suppliers to pass security requirements to their sub-suppliers.
- Request information on critical components and their origin.
- Require that products work as expected, without unexpected features.

5.21 Implementation guidance (2 of 2)

- Obtain assurance on component integrity (e.g. signed software, trusted sources).
- Plan for end of life and end of support of components.
- Manage risks of components that cannot be replaced easily.
- Share information on supply chain issues with suppliers.

5.21 In practice

Medical devices

The situation

- A device maker’s product relies on an open-source library
- A vulnerability is announced in that library

Applying the control

- Software bill of materials kept for each product
- Suppliers must report vulnerabilities and support dates
- Library update prioritized; customers informed

Typical evidence

- Component inventories (SBOM)
- Supplier clauses on flow-down and notification
- Records of response to the vulnerability

5.21 Two perspectives and common difficulties

Implementer's view

- Know the critical components and their origin
- Flow requirements down by contract
- Track support life of components

Auditor's view

- Which components are critical, and where from?
- Do contracts require flow-down?
- How was the last supply chain issue handled?

Common difficulties

- No visibility beyond the first supplier
- Unsupported components left in service
- Unverified software sources

Connections: 5.19–5.20 suppliers and agreements; 5.22 monitoring; 8.8 technical vulnerabilities; 8.30 outsourced development.

MSM ACADEMY

S3.2.22 · A.5 ORGANIZATIONAL CONTROLS

A.5.22 Monitoring, review and change management of supplier services

5.22

Annex A control

S3.2.22 · CONTROL 5.22

5.22 Monitoring, review and change management of supplier services

What the control asks

Regularly monitor, review, evaluate and manage change in supplier information security practices and service delivery.

Purpose

Maintain an agreed level of information security and service delivery in line with supplier agreements.

ISO/IEC 27002 attributes

Control type

Preventive

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Identify

Operational capabilities

Supplier relationships security · Information security assurance

Security domains

Governance and Ecosystem · Protection · Defence

5.22 What it means

- Monitoring is proportionate to supplier risk.
- Methods: service reports, certificates, questionnaires, audits, incident records.
- Changes by the supplier are assessed for security impact.
- Problems are followed up and escalated.

5.22 Implementation guidance

- Assign a relationship owner for each important supplier.
- Review service reports and performance against the agreement.
- Review independent assurance (certificates, audit reports) and their scope.
- Assess supplier changes and incidents; adjust controls or contracts.
- Reassess suppliers periodically; act on poor performance.

5.22 In practice

Insurance

The situation

- An insurer’s claims-processing outsourcer changed data centres without telling anyone
- Its certificate covered a different service

Applying the control

- Quarterly service reviews with a security agenda
- Certificate scope checked against the service bought
- Contract requires notice of significant changes

Typical evidence

- Supplier review schedule and records
- Reviewed certificates and their scope
- Actions from reviews

5.22 Two perspectives and common difficulties

Implementer's view

- Scale monitoring to risk
- Check the scope of supplier certificates
- Make overdue reviews visible

Auditor's view

- Pick a critical supplier: when was it last reviewed?
- Was its certificate scope checked?
- How were supplier changes assessed?

Common difficulties

- Reviews done only at onboarding
- Certificates accepted without scope check
- Supplier changes unnoticed

Connections: 5.19–5.21 supplier controls; 5.23 cloud; ISO/IEC 27001 8.1; 5.24 incident management.

MSM ACADEMY

S3.2.23 · A.5 ORGANIZATIONAL CONTROLS

A.5.23 Information security for use of cloud services

5.23

Annex A control · New in 2022

S3.2.23 · CONTROL 5.23

5.23 Information security for use of cloud services

NEW IN 2022

What the control asks

Establish processes for the acquisition, use, management and exit from cloud services in accordance with the organization’s information security requirements.

Purpose

Specify and manage information security for the use of cloud services.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Supplier relationships security

Security domains
Governance and Ecosystem · Protection

5.23 What it means

- Shared responsibility: provider and customer each own different controls.
- A topic-specific cloud policy defines what may go to the cloud and how.
- Customers must manage their own configuration, identities and data.
- Plan exit before entry: data portability and deletion.

5.23 Implementation guidance (1 of 2)

- Define requirements: data location, encryption, access, logging, availability.
- Select providers on evidence: certifications, reports, contract terms.
- Understand and document the shared responsibility split.
- Approve cloud services; prevent unsanctioned “shadow” cloud use.

5.23 Implementation guidance (2 of 2)

- Manage configuration, identities and keys on the customer side.
- Monitor the service and provider notifications; manage changes.
- Agree incident notification and support for investigations.
- Exit strategy: data return in usable format, deletion, transition.

5.23 In practice

Charity

The situation

- A charity stores donor data in several cloud apps chosen by different teams
- One storage bucket was left public

Applying the control

- Approved cloud service list and request process
- Shared responsibility documented per service
- Configuration baseline and monthly checks
- Exit plan for donor data

Typical evidence

- Cloud policy and approved list
- Responsibility matrices
- Configuration check results
- Exit plans

5.23 Two perspectives and common difficulties

Implementer's view

- Document the shared responsibility split
- Secure customer-side configuration
- Plan exit before entry

Auditor's view

- Which cloud services are in use, and which are approved?
- Who manages configuration and keys?
- Is there a tested exit plan?

Common difficulties

- Assuming the provider secures everything
- Shadow cloud services
- No way to retrieve data at exit

Connections: 5.19–5.22 supplier controls; 8.9 configuration; 8.24 cryptography; 5.30 ICT continuity; 8.10 deletion.

Lesson 3.4 recap

- 5.19: supplier risk managed across the whole relationship
- 5.20: security requirements agreed in each contract
- 5.21: requirements flow down the ICT supply chain
- 5.22–5.23: suppliers monitored; cloud use governed with shared responsibility and exit plans

Check your understanding

A company uses a certified cloud provider and assumes this covers all cloud security. Its storage was misconfigured and exposed data.

A The provider is responsible because it is certified

B Shared responsibility: customer configuration is the customer’s duty under 5.23

C 5.23 does not apply to certified providers

D Only an incident-management issue

Check your understanding

A company uses a certified cloud provider and assumes this covers all cloud security. Its storage was misconfigured and exposed data.

A. The provider is responsible because it is certified

B. Shared responsibility: customer configuration is the customer's duty under 5.23

C. 5.23 does not apply to certified providers

D. Only an incident-management issue

Answer: B

Under shared responsibility, the customer manages its own configuration, identities and data. The provider's certificate does not cover them.

MSM ACADEMY

SECTION 3 · LESSON 3.5

A.5 Incidents and continuity

3.5

Controls 5.24–5.30: incident management, from planning to evidence, and continuity during disruption.

MSM ACADEMY

S3.2.24 · A.5 ORGANIZATIONAL CONTROLS

A.5.24 Information security incident management planning and preparation

5.24

Annex A control

S3.2.24 · CONTROL 5.24

5.24 Information security incident management planning and preparation

What the control asks

Plan and prepare for managing information security incidents by defining, establishing and communicating incident management processes, roles and responsibilities.

Purpose

Ensure quick, effective, consistent and orderly response to information security incidents, including communication on events.

ISO/IEC 27002 attributes

Control type

Corrective

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Respond · Recover

Operational capabilities

Governance · Information security event management

Security domains

Defence

5.24 What it means

- A defined incident management process, from detection to lessons learned.
- Clear roles: who reports, who assesses, who decides, who communicates.
- Competent people, with training and exercises.
- Links to legal reporting, suppliers and crisis management.

5.24 Implementation guidance (1 of 2)

- Establish a common method for reporting events (6.8) and a point of contact.
- Define the incident response team, roles and escalation paths.
- Define criteria for classifying and prioritizing incidents.
- Prepare procedures and playbooks for likely incident types.

5.24 Implementation guidance (2 of 2)

- Plan communication: internal, customers, authorities (5.5), media.
- Align with legal and contractual notification deadlines.
- Train responders and run exercises.
- Keep tools, contact lists and documentation ready and current.

5.24 In practice

E-commerce

The situation

- An online shop has no incident process; IT handles problems ad hoc
- A data breach would trigger a 72-hour regulator deadline

Applying the control

- Incident procedure with severity levels and roles
- Playbooks for ransomware, account takeover and data leaks
- Annual tabletop exercise with management

Typical evidence

- Incident management procedure
- Role assignments and contact lists
- Exercise reports and improvements

5.24 Two perspectives and common difficulties

Implementer's view

- Define roles and escalation before you need them
- Build playbooks for likely incidents
- Exercise the plan

Auditor's view

- Who is on the response team, and are they trained?
- Are notification deadlines built in?
- When was the plan last exercised?

Common difficulties

- Plans written but never exercised
- Unclear authority to escalate
- Notification deadlines missed

Connections: 5.25–5.28 incident controls; 6.8 event reporting; 5.5 authorities; 5.29–5.30 continuity; 8.16 monitoring.

MSM ACADEMY

S3.2.25 · A.5 ORGANIZATIONAL CONTROLS

A.5.25 Assessment and decision on information security events

5.25

Annex A control

S3.2.25 · CONTROL 5.25

5.25 Assessment and decision on information security events

What the control asks

Assess information security events and decide if they are to be categorized as information security incidents.

Purpose

Ensure effective categorization and prioritization of information security events.

ISO/IEC 27002 attributes

Control type
Detective

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Detect · Respond

Operational capabilities
Information security event management

Security domains
Defence

5.25 What it means

- An event is any occurrence that may indicate a security issue; an incident is one that actually harms or threatens operations or information.
- Assessment uses an agreed categorization and prioritization scheme.
- A point of contact or team assesses each reported event.
- Results of the assessment are recorded.

5.25 Implementation guidance

- Agree a categorization and prioritization scheme with clear criteria.
- Assess events promptly against the scheme.
- Record the decision and the reasoning; escalate incidents to response.
- Review decisions later to improve the criteria.

5.25 In practice

Telecom

The situation

- A telecom operator’s monitoring raises hundreds of alerts a day
- Analysts decide informally what matters

Applying the control

- Triage criteria with severity levels
- Each alert assessed and logged as event or incident
- Weekly review of borderline decisions

Typical evidence

- Categorization scheme
- Event and incident log with decisions
- Review notes

5.25 Two perspectives and common difficulties

Implementer's view

- Define clear triage criteria
- Record every decision
- Learn from misclassified events

Auditor's view

- How are events categorized?
- Sample an event: was the decision recorded?
- Were any incidents missed?

Common difficulties

- Informal triage
- Incidents treated as routine events
- No record of why an event was dismissed

Connections: 5.24 planning; 5.26 response; 6.8 event reporting; 8.15–8.16 logging and monitoring.

MSM ACADEMY

S3.2.26 · A.5 ORGANIZATIONAL CONTROLS

A.5.26 Response to information security incidents

5.26

Annex A control

S3.2.26 · CONTROL 5.26

5.26 Response to information security incidents

What the control asks

Respond to information security incidents in accordance with the documented procedures.

Purpose

Ensure efficient and effective response to information security incidents.

ISO/IEC 27002 attributes

Control type
Corrective

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Respond · Recover

Operational capabilities
Information security event management

Security domains
Defence

5.26 What it means

- Contain the incident, then eradicate the cause and recover.
- Escalate and communicate as defined, including to authorities and customers.
- Collect evidence where needed (5.28).
- Log all response activities for later analysis.

5.26 Implementation guidance (1 of 2)

- Contain: isolate affected systems or accounts to limit spread.
- Collect evidence as soon as possible, preserving it properly.
- Escalate as required, including crisis management.

5.26 Implementation guidance (2 of 2)

- Communicate to internal and external parties on a need-to-know basis.
- Coordinate with suppliers, authorities and specialists.
- Eradicate the cause; recover systems and data.
- Formally close the incident and record it.

5.26 In practice

Manufacturing

The situation

Ransomware encrypts file servers at a factory on a weekend

Applying the control

- Infected network segment isolated
- Playbook followed: evidence preserved, insurer and authority notified
- Systems restored from backup; incident closed with timeline

Typical evidence

- Incident record and timeline
- Communications log
- Restoration records
- Closure report

5.26 Two perspectives and common difficulties

Implementer's view

- Prioritize containment
- Follow and log the procedure
- Close incidents formally

Auditor's view

- Sample an incident: does the record follow the procedure?
- Was communication timely?
- Was it formally closed?

Common difficulties

- Restoring before containing
- Undocumented response steps
- Incidents left open indefinitely

Connections: 5.24 planning; 5.25 assessment; 5.27 learning; 5.28 evidence; 8.13 backup.

MSM ACADEMY

S3.2.27 · A.5 ORGANIZATIONAL CONTROLS

A.5.27 Learning from information security incidents

5.27

Annex A control

S3.2.27 · CONTROL 5.27

5.27 Learning from information security incidents

What the control asks

Use knowledge gained from information security incidents to strengthen and improve the information security controls.

Purpose

Reduce the likelihood or consequences of future incidents.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify · Protect

Operational capabilities
Information security event management

Security domains
Defence

5.27 What it means

- Review significant incidents after closure.
- Quantify and analyse types, volumes and costs of incidents.
- Update controls, risk assessment, playbooks and awareness.
- Share lessons where useful, including with users.

5.27 Implementation guidance

- Hold a post-incident review for significant incidents.
- Identify causes and contributing factors, not just the trigger.
- Feed results into risk assessment and control improvement.
- Track improvement actions to completion.
- Use incident trends in management review.

5.27 In practice

Logistics

The situation

Three account takeovers in six months, all through reused passwords

Applying the control

- Review identifies missing MFA as the common cause
- MFA introduced for remote access
- Awareness campaign on password reuse

Typical evidence

- Post-incident review reports
- Improvement actions and their status
- Incident trend data for management review

5.27 Two perspectives and common difficulties

Implementer's view

- Review significant incidents systematically
- Look for common causes across incidents
- Track actions to completion

Auditor's view

- Which controls changed because of incidents?
- Are trends analysed?
- Are actions closed?

Common difficulties

- Reviews that only describe what happened
- Repeated incidents of the same type
- Actions never completed

Connections: 5.26 response; ISO/IEC 27001 6.1.2 risk assessment, 9.3 management review, 10.2 corrective action; 6.3 awareness.

MSM ACADEMY

S3.2.28 · A.5 ORGANIZATIONAL CONTROLS

A.5.28 Collection of evidence

Annex A control

5.28

S3.2.28 · CONTROL 5.28

5.28 Collection of evidence

What the control asks

Establish and implement procedures for the identification, collection, acquisition and preservation of evidence related to information security events.

Purpose

Ensure consistent and effective management of evidence related to information security incidents for disciplinary and legal actions.

ISO/IEC 27002 attributes

Control type
Corrective

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Detect · Respond

Operational capabilities
Information security event management

Security domains
Defence

5.28 What it means

- Evidence may be needed for court, regulators, insurers or disciplinary action.
- Its value depends on integrity and a documented chain of custody.
- Different jurisdictions have different rules on admissibility.
- Specialist forensic support may be needed.

5.28 Implementation guidance

- Identify what evidence may be needed and where it resides.
- Collect it with tools and methods that preserve integrity.
- Record chain of custody: who, when, where, how.
- Protect evidence storage and limit access.
- Know when to call forensic specialists or law enforcement.

5.28 In practice

Bank

The situation

An employee is suspected of copying customer data before resigning

Applying the control

- Laptop seized and imaged by a forensic specialist
- Hash values and chain-of-custody form recorded
- Evidence stored securely for HR and legal

Typical evidence

- Evidence procedure
- Chain-of-custody forms
- Forensic reports with hash values

5.28 Two perspectives and common difficulties

Implementer's view

- Prepare the procedure and contacts in advance
- Preserve before you investigate
- Document chain of custody

Auditor's view

- Is there a procedure, and do responders know it?
- For a past case, was custody documented?
- Is log retention long enough to support evidence?

Common difficulties

- Staff examine devices and alter evidence
- No chain of custody
- Logs overwritten before collection

Connections: 5.26 response; 5.31 legal requirements; 6.4 disciplinary process; 8.15 logging.

MSM ACADEMY

S3.2.29 · A.5 ORGANIZATIONAL CONTROLS

A.5.29 Information security during disruption

5.29

Annex A control

S3.2.29 · CONTROL 5.29

5.29 Information security during disruption

What the control asks

Plan how to maintain information security at an appropriate level during disruption.

Purpose

Protect information and other associated assets during disruption.

ISO/IEC 27002 attributes

Control type
Preventive · Corrective

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect · Respond

Operational capabilities
Continuity

Security domains
Protection · Resilience

5.29 What it means

- Disruptions: outages, disasters, pandemics, cyber attacks.
- Security must continue, perhaps in a different form, during disruption.
- Business continuity plans include security requirements.
- Controls are maintained or replaced by alternatives, then restored.

5.29 Implementation guidance (1 of 2)

- Determine security requirements for continuity situations.

- Include them in business continuity and recovery plans.

5.29 Implementation guidance (2 of 2)

- Maintain controls during disruption, or define compensating ones.
- Protect information at alternative sites and during remote working.
- Test plans, including the security aspects.
- Restore normal controls after disruption.

5.29 In practice

Public sector

The situation

- During a flood, a council moves staff to a temporary office
- Staff start using personal email to keep services running

Applying the control

- Continuity plan includes secure remote access and approved devices
- Emergency access granted with logging and expiry
- Normal controls restored and emergency access removed afterwards

Typical evidence

- Continuity plans with security requirements
- Test reports
- Records of emergency access and its removal

5.29 Two perspectives and common difficulties

Implementer's view

- Put security requirements into continuity plans
- Define compensating controls for emergencies
- Remove emergency access afterwards

Auditor's view

- Do continuity plans address security?
- Were security aspects tested?
- Was emergency access removed?

Common difficulties

- Security dropped “for the emergency”
- Plans tested without security aspects
- Emergency access left in place

Connections: 5.30 ICT readiness; 5.24–5.26 incidents; 8.13–8.14 backup and redundancy; 7.11 utilities.

MSM ACADEMY

S3.2.30 · A.5 ORGANIZATIONAL CONTROLS

A.5.30 ICT readiness for business continuity

5.30

Annex A control · New in 2022

S3.2.30 · CONTROL 5.30

NEW IN 2022

5.30 ICT readiness for business continuity

What the control asks

Plan, implement, maintain and test ICT readiness based on business continuity objectives and ICT continuity requirements.

Purpose

Ensure the availability of the organization’s information and other associated assets during disruption.

ISO/IEC 27002 attributes

Control type
Corrective

Security properties
Availability

Cybersecurity concepts
Respond

Operational capabilities
Continuity

Security domains
Resilience

5.30 What it means

- Starts with a business impact analysis: which activities matter, how fast they must recover.
- Sets recovery objectives: recovery time (RTO) and recovery point (RPO).
- ICT continuity plans and capabilities must be able to meet them.
- Plans are tested against the objectives.

5.30 Implementation guidance (1 of 2)

- Perform a business impact analysis to set priorities and objectives.
- Define ICT continuity requirements: RTO, RPO, capacity.
- Design ICT continuity capabilities to meet them.

5.30 Implementation guidance (2 of 2)

- Assign responsibilities and document ICT continuity plans.
- Test and exercise plans regularly against the objectives.
- Update plans after changes and test results.
- Consider suppliers’ continuity capabilities.

5.30 In practice

Online retail

The situation

An online retailer says checkout “must never stop” but has one data centre

Applying the control

- Impact analysis sets checkout RTO 2 hours, RPO 15 minutes
- Replication to a second region
- Twice-yearly failover tests measured against RTO and RPO

Typical evidence

- Business impact analysis
- ICT continuity plans
- Test results compared with objectives

5.30 Two perspectives and common difficulties

Implementer's view

- Derive objectives from business impact
- Build capability to meet them
- Test against the objectives

Auditor's view

- Where do RTO and RPO come from?
- Have tests met them?
- Are supplier dependencies covered?

Common difficulties

- Objectives with no supporting capability
- Tests that do not measure recovery time
- Untested plans

Connections: 5.29 security during disruption; 8.13 backup; 8.14 redundancy; 5.23 cloud; 7.11 utilities.

LESSON 3.5 · RECAP

Lesson 3.5 recap

- 5.24–5.26: plan, assess and respond to incidents
- 5.27–5.28: learn from incidents; preserve evidence properly
- 5.29: keep security during disruption
- 5.30: ICT able to meet continuity objectives, proven by tests

Check your understanding

A failover test restored systems in 9 hours. The business impact analysis set a recovery time objective of 4 hours. The test was recorded as “successful”.

A Successful: systems were restored

B A gap: the test did not meet the objective set for 5.30

C Only a 5.29 issue

D Acceptable if the next test is faster

Check your understanding

A failover test restored systems in 9 hours. The business impact analysis set a recovery time objective of 4 hours. The test was recorded as “successful”.

A. Successful: systems were restored

B. A gap: the test did not meet the objective set for 5.30

C. Only a 5.29 issue

D. Acceptable if the next test is faster

Answer: B

5.30 requires ICT readiness to meet continuity objectives. A test that misses the RTO shows the capability is not yet adequate.

MSM ACADEMY

SECTION 3 · LESSON 3.6

A.5 Legal, privacy, review and procedures

3.6

Controls 5.31–5.37: legal requirements, intellectual property, records, privacy, independent review, compliance and procedures.

MSM ACADEMY

S3.2.31 · A.5 ORGANIZATIONAL CONTROLS

A.5.31 Legal, statutory, regulatory and contractual requirements

5.31

Annex A control

S3.2.31 · CONTROL 5.31

5.31 Legal, statutory, regulatory and contractual requirements

What the control asks

Identify, document and keep up to date legal, statutory, regulatory and contractual requirements relevant to information security and the organization’s approach to meeting them.

Purpose

Ensure compliance with legal, statutory, regulatory and contractual requirements related to information security.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify

Operational capabilities
Legal and compliance

Security domains
Governance and Ecosystem · Protection

5.31 What it means

- A register of requirements: laws, regulations, contracts, with their source.
- Each requirement linked to the controls that meet it.
- Includes cryptography laws and cross-border data rules.
- Kept current as laws, contracts and operations change.

5.31 Implementation guidance (1 of 2)

- Identify requirements in every jurisdiction where the organization operates.
- Include contractual requirements from customers and partners.
- Assign responsibility for monitoring changes.

5.31 Implementation guidance (2 of 2)

- Consider cryptography rules: import, export and use restrictions.
- Consider requirements on record retention, reporting and data transfer.
- Link each requirement to controls and owners.
- Review the register periodically and on change.

5.31 In practice

SaaS

The situation

- A software company sells to customers in several countries
- Its legal requirements are known only to the founders

Applying the control

- Legal and contractual register by country and customer
- Each entry linked to controls and an owner
- Quarterly review by legal

Typical evidence

- Legal and contractual register
- Links to controls
- Review records and change log

5.31 Two perspectives and common difficulties

Implementer's view

- Build a register with sources
- Link requirements to controls
- Assign someone to watch for changes

Auditor's view

- Is the register complete for the scope?
- Pick a requirement: which control meets it?
- How are changes detected?

Common difficulties

- Register created once and never updated
- Contractual requirements omitted
- No link to controls

Connections: ISO/IEC 27001 4.2 interested parties; 5.32–5.34 IP, records and privacy; 5.20 supplier agreements; 8.24 cryptography.

MSM ACADEMY

S3.2.32 · A.5 ORGANIZATIONAL CONTROLS

A.5.32 Intellectual property rights

Annex A control

5.32

S3.2.32 · CONTROL 5.32

5.32 Intellectual property rights

What the control asks

Implement appropriate procedures to protect intellectual property rights.

Purpose

Ensure compliance with legal, statutory, regulatory and contractual requirements related to intellectual property rights and the use of proprietary products.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify

Operational capabilities
Legal and compliance

Security domains
Governance and Ecosystem

5.32 What it means

- Covers others’ IP the organization uses: software licences, fonts, images, standards.
- Covers the organization’s own IP: designs, code, trade secrets.
- Licensed products used only within licence terms.
- Acquired only from reputable sources.

5.32 Implementation guidance

- Publish a topic-specific policy on IP and acceptable software use.
- Keep proof of licence ownership and a licence register.
- Check usage against licences (e.g. number of users).
- Prevent installation of unauthorized software.
- Protect the organization’s own IP through contracts and access control.

5.32 In practice

Design studio

The situation

- Designers use fonts and stock images without checking licences
- A client asks for proof of rights

Applying the control

- Licence register for fonts, images and software
- Approved sources only
- Contracts protect the studio’s own designs

Typical evidence

- Licence register and proofs
- Software inventory compared with licences
- IP clauses in contracts

5.32 Two perspectives and common difficulties

Implementer's view

- Keep a licence register with proofs
- Restrict software installation
- Protect own IP contractually

Auditor's view

- Does installed software match licences?
- Are proofs of ownership kept?
- How is own IP protected?

Common difficulties

- Over-deployment beyond licences
- Unknown sources of software or media
- Own IP unprotected in contracts

Connections: 5.31 legal requirements; 8.19 software installation; 6.6 confidentiality agreements; 5.9 inventory.

MSM ACADEMY

S3.2.33 · A.5 ORGANIZATIONAL CONTROLS

A.5.33 Protection of records

5.33

Annex A control

S3.2.33 · CONTROL 5.33

5.33 Protection of records

What the control asks

Protect records from loss, destruction, falsification, unauthorized access and unauthorized release.

Purpose

Ensure compliance with legal, statutory, regulatory and contractual requirements, and community or societal expectations, related to the protection and availability of records.

ISO/IEC 27002 attributes

Control type

Preventive

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Identify · Protect

Operational capabilities

Legal and compliance · Asset management · Information protection

Security domains

Defence

5.33 What it means

- Records: evidence of activities, such as financial, HR, medical or legal records.
- Retention periods come from laws, contracts and business needs.
- Records stay readable and authentic for their whole retention period.
- Disposal at the end of retention is controlled.

5.33 Implementation guidance

- Define record types, retention periods and storage media.
- Keep a retention schedule linked to legal requirements.
- Protect integrity (e.g. write-once storage, signatures) and confidentiality.
- Plan for format and media obsolescence; keep the means to read records.
- Dispose of records securely at the end of retention.

5.33 In practice

Clinic

The situation

- A clinic must keep patient records for many years
- Old records sit on obsolete backup tapes

Applying the control

- Retention schedule by record type
- Records migrated to supported storage with integrity checks
- Secure destruction at end of retention

Typical evidence

- Retention schedule
- Migration and integrity check records
- Destruction certificates

5.33 Two perspectives and common difficulties

Implementer's view

- Map record types to retention rules
- Protect integrity and readability over time
- Control disposal

Auditor's view

- Is there a retention schedule?
- Can old records still be read?
- How is disposal evidenced?

Common difficulties

- Keeping everything forever
- Records unreadable after migrations
- Early destruction

Connections: 5.31 legal requirements; 5.34 privacy; 8.10 deletion; 8.13 backup; 7.10 storage media.

MSM ACADEMY

S3.2.34 · A.5 ORGANIZATIONAL CONTROLS

A.5.34 Privacy and protection of personal identifiable information (PII)

5.34

Annex A control

S3.2.34 · CONTROL 5.34

5.34 Privacy and protection of personal identifiable information (PII)

What the control asks

Identify and meet the requirements regarding the preservation of privacy and protection of personally identifiable information (PII) according to applicable laws, regulations and contractual requirements.

Purpose

Ensure compliance with legal, statutory, regulatory and contractual requirements related to the information security aspects of the protection of PII.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify · Protect

Operational capabilities
Information protection · Legal and compliance

Security domains
Protection

5.34 What it means

- Personal data is protected under privacy laws in most jurisdictions.
- A topic-specific privacy policy is communicated to those processing PII.
- Responsibility is assigned, often a privacy officer.
- Technical and organizational measures protect PII.

5.34 Implementation guidance (1 of 2)

- Identify the PII processed, its purposes and its legal basis.
- Know which privacy laws and contracts apply.
- Assign responsibility for privacy.

5.34 Implementation guidance (2 of 2)

- Apply measures: access control, encryption, minimization, masking, retention.
- Handle data subject requests and privacy breaches, with notification.
- Manage processors through agreements (5.20).
- Consider ISO/IEC 27701 for a privacy information management system.

5.34 In practice

Fitness app

The situation

A fitness app collects health and location data from millions of users

Applying the control

- Records of processing and a privacy policy
- Encryption, minimization and masking in test
- Breach procedure with regulator and user notification
- Processor agreements with cloud and analytics providers

Typical evidence

- Privacy policy and records of processing
- Technical measures in place
- Breach log and notifications
- Processor agreements

5.34 Two perspectives and common difficulties

Implementer's view

- Map personal data and legal bases
- Apply proportionate technical measures
- Build breach notification into incident response

Auditor's view

- What PII is processed, and where?
- Which measures protect it?
- How are privacy breaches notified?

Common difficulties

- Not knowing where PII is
- Personal data in test environments
- Missing processor agreements

Connections: 5.31 legal requirements; 5.33 records; 8.11 data masking; 5.20 supplier agreements; 5.24–5.26 incidents.

MSM ACADEMY

S3.2.35 · A.5 ORGANIZATIONAL CONTROLS

A.5.35 Independent review of information security

5.35

Annex A control

S3.2.35 · CONTROL 5.35

5.35 Independent review of information security

What the control asks

The organization’s approach to managing information security and its implementation, including people, processes and technologies, is reviewed independently at planned intervals, or when significant changes occur.

Purpose

Ensure the continuing suitability, adequacy and effectiveness of the organization’s approach to managing information security.

ISO/IEC 27002 attributes

Control type
Preventive · Corrective

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify · Protect

Operational capabilities
Information security assurance

Security domains
Governance and Ecosystem

5.35 What it means

- Independent review: by people not responsible for the area reviewed.
- Can be internal audit, an external firm or a peer function.
- Covers the whole approach, not just individual controls.
- Results go to management, who act on them.

5.35 Implementation guidance

- Plan reviews at defined intervals and after significant change.
- Select reviewers with competence and independence.
- Report results to the management that commissioned the review.
- Act on findings: corrective action and improvement.
- Keep records of reviews and their outcomes.

5.35 In practice

Fintech

The situation

- A fintech scales from 50 to 300 staff in two years
- Its security approach was designed for a startup

Applying the control

- External review of the security approach after the growth
- Findings presented to the board
- Improvement plan tracked

Typical evidence

- Review reports
- Board minutes
- Improvement plan and status

5.35 Two perspectives and common difficulties

Implementer's view

- Plan reviews and trigger them on change
- Ensure reviewer independence
- Track findings to closure

Auditor's view

- When was the last independent review?
- Were reviewers independent?
- Were findings acted on?

Common difficulties

- Reviews by the people responsible
- No review after major change
- Findings not acted on

Connections: ISO/IEC 27001 9.2 internal audit, 9.3 management review; 5.36 compliance; 8.34 audit testing.

MSM ACADEMY

S3.2.36 · A.5 ORGANIZATIONAL CONTROLS

A.5.36 Compliance with policies, rules and standards for information security

5.36

Annex A control

S3.2.36 · CONTROL 5.36

5.36 Compliance with policies, rules and standards for information security

What the control asks

Regularly review compliance with the organization’s information security policy, topic-specific policies, rules and standards.

Purpose

Ensure information security is implemented and operated in accordance with the organization’s policies, rules and standards.

ISO/IEC 27002 attributes

Control type

Preventive

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Identify · Protect

Operational capabilities

Legal and compliance · Information security assurance

Security domains

Governance and Ecosystem

5.36 What it means and how it is done

- Managers, owners and service owners check compliance in their own areas.
- Technical compliance can be checked with automated tools.
- Non-compliance is analysed for cause, and corrected.
- Results are recorded and reported.
- Different from 5.35: here it is regular checking by those responsible.

5.36 In practice

Retail

The situation

- Store managers are meant to check clear-desk and till security monthly
- Nobody knows if they do

Applying the control

- Monthly compliance checklist per store
- Automated scans for till configuration
- Results reported regionally and followed up

Typical evidence

- Completed checklists
- Scan reports
- Corrective action records

5.36 Two perspectives and common difficulties

Implementer's view

- Give owners simple compliance checks
- Automate technical checks
- Follow up non-compliance

Auditor's view

- Are compliance reviews done and recorded?
- Is non-compliance followed up?
- Are causes analysed?

Common difficulties

- Checks that are never done
- Findings without action
- Only technical checks, no process checks

Connections: 5.35 independent review; 5.1 policies; ISO/IEC 27001 9.1 and 10.2; 8.8–8.9 vulnerability and configuration checks.

MSM ACADEMY

S3.2.37 · A.5 ORGANIZATIONAL CONTROLS

A.5.37 Documented operating procedures

5.37

Annex A control

S3.2.37 · CONTROL 5.37

5.37 Documented operating procedures

What the control asks

Document operating procedures for information processing facilities and make them available to personnel who need them.

Purpose

Ensure the correct and secure operation of information processing facilities.

ISO/IEC 27002 attributes

Control type

Preventive · Corrective

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Protect · Recover

Operational capabilities

Asset management · Physical security · System and network security · Application security · Secure configuration · Identity and access management · Threat and vulnerability management · Continuity · Information security event management

Security domains

Governance and Ecosystem · Protection · Defence

5.37 What it means and how it is done

- Procedures for activities done often, by many people, or rarely and critically.
- Examples: backup and restore, system start-up, patching, handling errors.
- Procedures are approved, kept current and available.
- They support consistent operation and reduce reliance on individuals.
- Level of detail matches risk and competence.

5.37 In practice

Data centre

The situation

Only one engineer knows how to restore the main database

Applying the control

- Restore procedure documented and approved
- Tested by another engineer
- Stored where it is available during an outage

Typical evidence

- Documented procedures with versions
- Evidence of review
- Records of procedures being used or tested

5.37 Two perspectives and common difficulties

Implementer's view

- Document critical and infrequent procedures first
- Test procedures with someone else
- Keep them available during outages

Auditor's view

- Do procedures exist for critical operations?
- Are they current and used?
- Could someone else follow them?

Common difficulties

- Knowledge held by one person
- Outdated procedures
- Procedures stored only on the system they recover

Connections: 5.1 policies; ISO/IEC 27001 7.5 documented information; 8.13 backup; 8.32 change management.

Lesson 3.6 recap

- 5.31–5.33: legal requirements, intellectual property and records
- 5.34: privacy and personal data protected
- 5.35–5.36: independent review and regular compliance checks
- 5.37: documented procedures for consistent, secure operation

Check your understanding

The ISMS manager reviews the ISMS herself every year and calls it the “independent review”.

A Meets 5.35: she knows the system best

B Does not meet 5.35: the reviewer must not be responsible for the area reviewed

C Meets 5.36 instead, so no gap

D Independent review is only needed for certification

Check your understanding

The ISMS manager reviews the ISMS herself every year and calls it the “independent review”.

A. Meets 5.35: she knows the system best

B. Does not meet 5.35: the reviewer must not be responsible for the area reviewed

C. Meets 5.36 instead, so no gap

D. Independent review is only needed for certification

Answer: B

5.35 needs reviewers independent of the area reviewed. Her review may support 5.36, but it is not an independent review.

MSM ACADEMY

SECTION 3 · LESSON 3.7

A.6 People controls

Controls 6.1–6.8: from screening before employment to reporting events.



S3.3.1 · A.6 PEOPLE CONTROLS

A.6.1 Screening

Annex A control

6.1

6.1 Screening

What the control asks

Carry out background verification checks on all candidates prior to joining, and on an ongoing basis, taking into account laws, regulations and ethics, proportional to business requirements, the classification of information accessed and perceived risks.

Purpose

Ensure all personnel are eligible and suitable for the roles they are considered for and remain so during employment.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Human resource security

Security domains
Governance and Ecosystem

6.1 What it means

- Checks are proportionate: more for roles with sensitive access.
- Typical checks: identity, references, qualifications, employment history, sometimes criminal or credit records where lawful.
- Laws on screening differ by country; privacy applies.
- Applies to contractors too, possibly through their agency.

6.1 Implementation guidance

- Define screening levels by role and access.
- Get legal advice on what checks are permitted.
- Screen before access is granted, or apply interim controls.
- Re-screen periodically for high-risk roles, or on role change.
- Record that checks were done, while protecting the results.

6.1 In practice

Bank

The situation

A bank hires contractors through an agency without knowing what checks were done

Applying the control

- Screening levels defined by role
- Agency contract requires defined checks and evidence
- Access granted only after confirmation

Typical evidence

- Screening policy by role
- Agency confirmations
- Records of checks completed before access

6.1 Two perspectives and common difficulties

Implementer's view

- Define screening levels by role
- Get legal advice per country
- Link access to completed screening

Auditor's view

- Sample new starters: was screening done before access?
- Are contractors covered?
- Is screening proportionate?

Common difficulties

- Contractors skipped
- Access before screening
- Same checks for every role

Connections: 6.2 terms of employment; 6.6 confidentiality agreements; 5.19–5.20 supplier agreements; 5.34 privacy.

MSM ACADEMY

S3.3.2 · A.6 PEOPLE CONTROLS

A.6.2 Terms and conditions of employment

6.2

Annex A control

6.2 Terms and conditions of employment

What the control asks

The employment contractual agreements state the personnel's and the organization's responsibilities for information security.

Purpose

Ensure personnel understand their information security responsibilities for the roles for which they are considered.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Human resource security

Security domains
Governance and Ecosystem

6.2 What it means

- Contracts or terms reference security responsibilities and policies.
- They include confidentiality, legal responsibilities and consequences of breaches.
- Responsibilities that continue after employment are stated (6.5).
- Contractors’ agreements contain equivalent terms.

6.2 Implementation guidance

- Include security clauses in employment contracts and contractor agreements.
- Reference policies by name; require acknowledgement.
- Cover handling of information and assets, and legal duties.
- State consequences of non-compliance (6.4).
- Update terms when laws or policies change significantly.

6.2 In practice

Agency

The situation

A marketing agency’s freelancers sign no terms about client data

Applying the control

- Standard freelancer agreement with confidentiality and data handling clauses
- Policy acknowledgement on day one
- Terms reviewed annually

Typical evidence

- Contract templates with security clauses
- Signed agreements
- Acknowledgement records

6.2 Two perspectives and common difficulties

Implementer's view

- Add standard security clauses to all agreements
- Reference policies explicitly
- Include contractors

Auditor's view

- Do contracts contain security responsibilities?
- Are contractors covered?
- Are post-employment duties stated?

Common difficulties

- Old contracts without security terms
- Contractors on supplier terms only
- Policies not referenced

Connections: 6.1 screening; 6.4 disciplinary process; 6.5 after termination; 6.6 confidentiality; 5.10 acceptable use.

S3.3.3 · A.6 PEOPLE CONTROLS

A.6.3 Information security awareness, education and training

6.3

Annex A control

S3.3.3 · CONTROL 6.3

6.3 Information security awareness, education and training

What the control asks

Personnel and relevant interested parties receive appropriate information security awareness, education and training and regular updates of policies and procedures relevant to their job function.

Purpose

Ensure personnel and relevant interested parties are aware of and fulfil their information security responsibilities.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Human resource security

Security domains
Governance and Ecosystem

6.3 What it means

- Three levels: awareness (everyone), education and training (role-specific skills).
- Content follows the organization’s policies, risks and incidents.
- Delivered at onboarding and regularly, and after significant changes.
- Effectiveness is assessed, not just attendance.

6.3 Implementation guidance (1 of 2)

- Build an awareness programme based on roles and risks.
- Use varied methods: e-learning, briefings, campaigns, simulations.
- Cover policies, threats, reporting, and personal responsibilities.

6.3 Implementation guidance (2 of 2)

- Provide role-specific training: developers, administrators, managers.
- Include contractors and relevant third parties.
- Refresh regularly and after incidents or changes.
- Measure effectiveness and adjust the programme.

6.3 In practice

Hospital

The situation

Annual click-through training; staff still fall for phishing

Applying the control

- Short monthly topics tied to real incidents
- Phishing simulations with follow-up coaching
- Specific training for IT administrators and clinical system owners

Typical evidence

- Awareness plan
- Completion and simulation results
- Role-based training records
- Trend of reported phishing

6.3 Two perspectives and common difficulties

Implementer's view

- Base content on real risks and incidents
- Add role-specific training
- Measure behaviour, not attendance

Auditor's view

- Is training role-based?
- Are contractors included?
- How is effectiveness measured?

Common difficulties

- One generic annual course
- Contractors excluded
- Completion rates treated as success

Connections: ISO/IEC 27001 7.2 competence and 7.3 awareness; 5.4 management responsibilities; 6.8 reporting; 5.27 learning from incidents.

S3.3.4 · A.6 PEOPLE CONTROLS

A.6.4 Disciplinary process

Annex A control



6.4 Disciplinary process

What the control asks

Formalize and communicate a disciplinary process to take actions against personnel and other relevant interested parties who have committed an information security policy violation.

Purpose

Ensure personnel and other relevant interested parties understand the consequences of policy violation, deter violations, and deal appropriately with those who have committed them.

ISO/IEC 27002 attributes

Control type
Preventive · Corrective

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect · Respond

Operational capabilities
Human resource security

Security domains
Governance and Ecosystem

6.4 What it means and how it is done

- The process is formal, communicated and fair.
- Starts only after verification that a violation occurred.
- Graduated response: nature, gravity, intent, repetition, training received.
- Respects legal and contractual requirements, including evidence (5.28).
- Can also recognize good security behaviour.

6.4 In practice

Retail bank

The situation

A branch employee looked up a celebrity customer’s account out of curiosity

Applying the control

- Investigation confirms access was without business need
- Graduated sanction under the HR process
- Lesson shared in awareness training without naming the person

Typical evidence

- Documented disciplinary process
- Case records
- Communication of the process to staff

6.4 Two perspectives and common difficulties

Implementer's view

- Formalize the process with HR
- Communicate it in advance
- Verify before acting; respond proportionately

Auditor's view

- Is the process documented and known?
- Were past cases handled consistently?
- Was evidence properly preserved?

Common difficulties

- Inconsistent sanctions
- Acting before verification
- Staff unaware of consequences

Connections: 6.2 terms of employment; 5.28 evidence; 6.3 awareness; 6.8 reporting.

MSM ACADEMY

S3.3.5 · A.6 PEOPLE CONTROLS

A.6.5 Responsibilities after termination or change of employment

6.5

Annex A control

S3.3.5 · CONTROL 6.5

6.5 Responsibilities after termination or change of employment

What the control asks

Define, enforce and communicate information security responsibilities and duties that remain valid after termination or change of employment to relevant personnel and other interested parties.

Purpose

Protect the organization’s interests as part of the process of changing or terminating employment or contracts.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Human resource security · Asset management

Security domains
Governance and Ecosystem

6.5 What it means and how it is done

- Some duties continue: confidentiality, intellectual property, non-disclosure.
- They are defined in contracts (6.2) and confidentiality agreements (6.6).
- They are reminded at exit.
- Role changes are managed like a termination plus a new start.
- Applies to contractors and suppliers’ staff.

6.5 In practice

Technology

The situation

A senior engineer leaves to join a competitor

Applying the control

- Exit interview reminds of confidentiality and IP obligations
- Written acknowledgement obtained
- Access and assets handled under 5.11 and 5.18

Typical evidence

- Exit checklist including reminders
- Signed acknowledgements
- Contract clauses on continuing duties

6.5 Two perspectives and common difficulties

Implementer's view

- Define continuing duties in contracts
- Remind at exit, in writing
- Treat role changes properly

Auditor's view

- Do contracts define continuing duties?
- Are leavers reminded?
- Are role changes handled?

Common difficulties

- No exit reminder
- Role changes ignored
- Contractors not covered

Connections: 6.2 terms; 6.6 confidentiality; 5.11 return of assets; 5.18 access rights.

S3.3.6 · A.6 PEOPLE CONTROLS

A.6.6 Confidentiality or non-disclosure agreements

Annex A control



6.6 Confidentiality or non-disclosure agreements

What the control asks

Identify, document, regularly review and sign confidentiality or non-disclosure agreements reflecting the organization’s needs for the protection of information, by personnel and other relevant interested parties.

Purpose

Maintain confidentiality of information accessible by personnel or external parties.

ISO/IEC 27002 attributes

Control type

Preventive

Security properties

Confidentiality

Cybersecurity concepts

Protect

Operational capabilities

Human resource security · Information protection · Supplier relationships security

Security domains

Governance and Ecosystem

6.6 What it means and how it is done

- Agreements define the information covered and permitted use.
- They state duration, including after the relationship ends.
- They cover actions on termination: return or destruction.
- They are signed by employees, contractors and relevant third parties.
- They are reviewed when requirements change.

6.6 In practice

Biotech

The situation

Visiting researchers access unpublished data without any agreement

Applying the control

- Standard NDA for visitors and collaborators
- Signed before access is granted
- Templates reviewed by legal every two years

Typical evidence

- NDA templates
- Signed agreements
- Review records

6.6 Two perspectives and common difficulties

Implementer's view

- Use standard templates by party type
- Sign before access
- Review templates periodically

Auditor's view

- Are NDAs signed before access?
- Do they define duration and return?
- Are templates current?

Common difficulties

- Signed after access began
- Templates outdated
- Third parties forgotten

Connections: 6.2 terms; 6.5 after termination; 5.20 supplier agreements; 5.14 transfer.

MSM ACADEMY

S3.3.7 · A.6 PEOPLE CONTROLS

A.6.7 Remote working

Annex A control

6.7

6.7 Remote working

What the control asks

Implement security measures when personnel are working remotely to protect information accessed, processed or stored outside the organization’s premises.

Purpose

Ensure the security of information when personnel are working remotely.

ISO/IEC 27002 attributes

Control type

Preventive

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Protect

Operational capabilities

Asset management · Information protection · Physical security · System and network security

Security domains

Protection

6.7 What it means

- Covers home working, travel, hotels, client sites and public places.
- A topic-specific remote working policy sets conditions.
- Risks: overlooking, theft, insecure networks, family members, printing.
- Both technical and behavioural measures are needed.

6.7 Implementation guidance (1 of 2)

- Define which activities and information may be handled remotely.
- Provide secure remote access (VPN or equivalent) and managed devices.
- Require protection of devices: encryption, screen lock, updates.

6.7 Implementation guidance (2 of 2)

- Address physical security at home: storage, privacy, disposal of paper.
- Rules on use of personal devices and networks.
- Provide support, and a way to report incidents remotely.
- Revoke remote access when no longer needed.

6.7 In practice

Consultancy

The situation

Consultants work from cafés and client sites on personal laptops

Applying the control

- Managed, encrypted laptops with VPN
- Privacy screens and guidance for public places
- Remote working policy acknowledged

Typical evidence

- Remote working policy
- Device management reports
- Acknowledgements and training records

6.7 Two perspectives and common difficulties

Implementer's view

- Provide managed devices and secure access
- Set clear rules for public and home settings
- Support remote incident reporting

Auditor's view

- Are remote devices managed and encrypted?
- Is the policy known?
- How are remote incidents reported?

Common difficulties

- Personal devices with no control
- Public Wi-Fi without protection
- Paper printed at home and binned

Connections: 8.1 endpoint devices; 8.20 network security; 7.9 assets off-premises; 6.3 awareness; 8.24 cryptography.

MSM ACADEMY

S3.3.8 · A.6 PEOPLE CONTROLS

A.6.8 Information security event reporting

6.8

Annex A control

6.8 Information security event reporting

What the control asks

Provide a mechanism for personnel to report observed or suspected information security events through appropriate channels in a timely manner.

Purpose

Support timely, consistent and effective reporting of information security events that can be identified by personnel.

ISO/IEC 27002 attributes

Control type
Detective

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Detect

Operational capabilities
Information security event management

Security domains
Defence

6.8 What it means

- A simple, known channel: a button, a mailbox, a phone line.
- People report suspected events, without needing proof.
- People should not try to prove a weakness by testing it.
- Reporting is encouraged, never punished.

6.8 Implementation guidance

- Provide easy reporting channels, available to all including contractors.
- Explain what to report: phishing, lost devices, unusual behaviour, breaches of rules.
- Acknowledge reports and give feedback.
- Connect reports to event assessment (5.25).
- Promote reporting in awareness training.

6.8 In practice

University

The situation

Staff forward suspicious emails to colleagues instead of IT

Applying the control

- Report-phishing button in email client
- Automatic acknowledgement and feedback
- Reports feed the security team’s triage

Typical evidence

- Reporting procedure and channels
- Report volumes and response times
- Awareness material promoting reporting

6.8 Two perspectives and common difficulties

Implementer's view

- Make reporting one click or one call
- Give feedback
- Never punish honest reporting

Auditor's view

- Do staff know how to report?
- Are reports acknowledged and assessed?
- Are contractors able to report?

Common difficulties

- Hidden or complex channels
- Blame culture discouraging reports
- Reports not followed up

Connections: 5.24–5.25 incident planning and assessment; 6.3 awareness; 6.4 disciplinary process.

Lesson 3.7 recap

- 6.1–6.2: screening and contractual responsibilities before people start
- 6.3–6.4: awareness and training; a fair disciplinary process
- 6.5–6.6: duties that continue after leaving; confidentiality agreements
- 6.7–6.8: secure remote working; easy reporting of events

Check your understanding

Training completion is 100%, but phishing simulation click rates have not improved in a year.

A 6.3 is fully met: everyone completed training

B 6.3 requires awareness that works; effectiveness should drive changes

C Only 6.8 reporting matters

D Simulations are outside the scope of 6.3

Check your understanding

Training completion is 100%, but phishing simulation click rates have not improved in a year.

A. 6.3 is fully met: everyone completed training

B. 6.3 requires awareness that works; effectiveness should drive changes

C. Only 6.8 reporting matters

D. Simulations are outside the scope of 6.3

Answer: B

6.3 aims for people who are aware and fulfil their responsibilities. Unchanged behaviour shows the programme needs adjusting.

MSM ACADEMY

SECTION 3 · LESSON 3.8

A.7 Secure areas

3.8

Controls 7.1–7.7: perimeters, entry, offices, monitoring, environmental threats, secure areas and clear desk.

MSM ACADEMY

S3.4.1 · A.7 PHYSICAL CONTROLS

A.7.1 Physical security perimeters

Annex A control

7.1

S3.4.1 · CONTROL 7.1

7.1 Physical security perimeters

What the control asks

Define and use security perimeters to protect areas that contain information and other associated assets.

Purpose

Prevent unauthorized physical access, damage and interference to the organization’s information and other associated assets.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Physical security

Security domains
Protection

7.1 What it means

- Perimeters are defined by the risk of the assets inside.
- Layers: site, building, floor, room, rack.
- Perimeters are physically sound: walls, doors, windows without gaps.
- Controlled entry points and alarms where needed.

7.1 Implementation guidance

- Define and document perimeters and the location and strength of each.
- Make perimeters physically sound; check windows, roofs, ventilation.
- Control entry points; fit alarms and fire doors appropriately.
- Separate areas managed by the organization from those of others.
- Review perimeters after changes to buildings or use.

7.1 In practice

Shared office building

The situation

- A company rents one floor in a multi-tenant building
- Its server room has a false ceiling shared with the next tenant

Applying the control

- Perimeter layers defined: building, floor, server room
- Server room ceiling sealed; door alarmed
- Landlord responsibilities agreed for building perimeter

Typical evidence

- Site plans with perimeters
- Inspection records
- Agreement with landlord

7.1 Two perspectives and common difficulties

Implementer's view

- Define layered perimeters by risk
- Close hidden routes
- Clarify shared-building responsibilities

Auditor's view

- Walk the perimeter: any gaps?
- Are perimeters documented?
- Who is responsible in shared buildings?

Common difficulties

- False ceilings and raised floors ignored
- Propped-open doors
- Landlord responsibilities unclear

Connections: 7.2 physical entry; 7.3 offices and facilities; 7.4 monitoring; 7.6 working in secure areas.

MSM ACADEMY

S3.4.2 · A.7 PHYSICAL CONTROLS

A.7.2 Physical entry

Annex A control

7.2

7.2 Physical entry

What the control asks

Protect secure areas by appropriate entry controls and access points.

Purpose

Ensure only authorized physical access to the organization’s information and other associated assets occurs.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Physical security · Identity and access management

Security domains
Protection

7.2 What it means

- Entry is authorized, controlled and recorded.
- Methods: badges, PINs, biometrics, receptions, locks.
- Visitors are identified, escorted where needed, and logged.
- Delivery and loading areas are controlled and isolated.

7.2 Implementation guidance

- Grant physical access based on need, reviewed regularly.
- Use access control systems with logs; protect logs.
- Manage visitors: sign-in, badges, escort, sign-out.
- Control keys and access cards; remove access on exit.
- Isolate delivery areas; inspect incoming deliveries.

7.2 In practice

Research lab

The situation

Lab doors are opened with shared PIN codes unchanged for years

Applying the control

- Badge readers replacing shared codes
- Access reviewed quarterly by the lab manager
- Visitor log and escort rule for labs

Typical evidence

- Access control system logs
- Quarterly access reviews
- Visitor logs

7.2 Two perspectives and common difficulties

Implementer's view

- Use individual credentials with logging
- Review physical access like logical access
- Control visitors and deliveries

Auditor's view

- Who can enter, and was it reviewed?
- Are leavers’ cards disabled?
- Are visitors logged and escorted?

Common difficulties

- Shared codes
- Cards not returned
- Tailgating tolerated

Connections: 7.1 perimeters; 7.4 monitoring; 5.15 and 5.18 access control and rights; 5.11 return of assets.

MSM ACADEMY

S3.4.3 · A.7 PHYSICAL CONTROLS

A.7.3 Securing offices, rooms and facilities

7.3

Annex A control

7.3 Securing offices, rooms and facilities

What the control asks

Design and implement physical security for offices, rooms and facilities.

Purpose

Prevent unauthorized physical access, damage and interference to information and other associated assets in offices, rooms and facilities.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Physical security · Asset management

Security domains
Protection

7.3 What it means and how it is done

- Sensitive facilities sited away from public access.
- Buildings give minimal indication of their purpose where sensitive.
- Rooms with confidential activity protected from overlooking and overhearing.
- Directories and signs do not reveal sensitive locations.
- Doors and windows locked when unattended.

7.3 In practice

Bank

The situation

A bank’s ground-floor meeting room faces the street; client data visible on screens

Applying the control

- Frosted film on windows
- Screens positioned away from windows
- Sensitive meetings moved to interior rooms

Typical evidence

- Facility security assessment
- Before and after records
- Room booking rules

7.3 Two perspectives and common difficulties

Implementer's view

- Assess facilities for overlooking and overhearing
- Keep sensitive locations discreet
- Lock unattended rooms

Auditor's view

- Can sensitive work be seen or heard?
- Do signs reveal sensitive areas?
- Are rooms locked when empty?

Common difficulties

- Screens visible from outside
- Signs pointing to the server room
- Unlocked empty offices

Connections: 7.1 perimeters; 7.2 entry; 7.7 clear desk; 7.8 equipment siting.

MSM ACADEMY

S3.4.4 · A.7 PHYSICAL CONTROLS

A.7.4 Physical security monitoring

Annex A control · New in 2022

7.4

S3.4.4 · CONTROL 7.4

NEW IN 2022

7.4 Physical security monitoring

What the control asks

Continuously monitor premises for unauthorized physical access.

Purpose

Detect and deter unauthorized physical access.

ISO/IEC 27002 attributes

Control type

Preventive · Detective

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Protect · Detect

Operational capabilities

Physical security

Security domains

Protection · Defence

7.4 What it means

- Monitoring by guards, intruder alarms, video surveillance (CCTV) or similar.
- Coverage based on risk: entrances, secure areas, sensitive equipment.
- Alerts must reach someone who responds.
- Recordings and monitoring are subject to privacy laws.

7.4 Implementation guidance (1 of 2)

- Decide monitoring methods by risk: alarms, CCTV, guards.
- Cover external doors, secure areas and sensitive points.
- Protect the monitoring systems themselves from tampering.

7.4 Implementation guidance (2 of 2)

- Ensure alarms are monitored and responded to, 24/7 where needed.
- Test alarms and cameras regularly.
- Define retention of recordings, respecting privacy law.
- Restrict access to monitoring systems and recordings.

7.4 In practice

Data centre

The situation

A colocation data centre has cameras but nobody watches them at night

Applying the control

- Monitoring contract with a 24/7 security centre
- Door-forced and held-open alarms
- Monthly test of alarms and cameras

Typical evidence

- Monitoring arrangements
- Alarm logs and response records
- Test records
- Retention settings

7.4 Two perspectives and common difficulties

Implementer's view

- Monitor by risk
- Make sure alerts get a response
- Test the monitoring itself

Auditor's view

- Who responds to alarms, and how fast?
- Were tests performed?
- Are recordings retained lawfully?

Common difficulties

- Cameras nobody watches
- Alarms ignored or disabled
- Retention breaching privacy law

Connections: 7.1–7.2 perimeters and entry; 5.34 privacy; 5.24 incident management; 7.5 environmental threats.

S3.4.5 · A.7 PHYSICAL CONTROLS

A.7.5 Protecting against physical and environmental threats

7.5

Annex A control

7.5 Protecting against physical and environmental threats

What the control asks

Design and implement protection against physical and environmental threats, such as natural disasters and other intentional or unintentional physical threats to infrastructure.

Purpose

Prevent or reduce the consequences of events originating from physical and environmental threats.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Physical security

Security domains
Protection

7.5 What it means and how it is done

- Threats: fire, flood, earthquake, extreme heat, storms, explosion, civil unrest.
- Risk assessment before choosing a site and during operation.
- Protection: fire detection and suppression, flood sensors, raised floors.
- Specialist advice may be needed.
- Links to climate considerations in ISO/IEC 27001 4.1.

7.5 In practice

Manufacturing

The situation

A factory’s server room sits in a basement in a flood-prone area

Applying the control

- Server room relocated to an upper floor
- Water sensors and fire suppression installed
- Flood risk included in the risk assessment

Typical evidence

- Environmental risk assessment
- Installation and test records for sensors and suppression
- Site selection decisions

7.5 Two perspectives and common difficulties

Implementer's view

- Assess physical and environmental threats per site
- Install proportionate protection
- Test detection and suppression

Auditor's view

- Which threats were assessed?
- Are protections tested?
- Does it reflect the climate determination?

Common difficulties

- Basements and pipes over equipment
- Untested suppression systems
- Climate risk ignored

Connections: ISO/IEC 27001 4.1 climate change; 7.8 equipment siting; 7.11 utilities; 5.29–5.30 continuity.

MSM ACADEMY

S3.4.6 · A.7 PHYSICAL CONTROLS

A.7.6 Working in secure areas

Annex A control

7.6

7.6 Working in secure areas

What the control asks

Design and implement security measures for working in secure areas.

Purpose

Protect information and other associated assets in secure areas from damage and unauthorized interference by personnel working in these areas.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Physical security

Security domains
Protection

7.6 What it means and how it is done

- Personnel know secure areas exist only on a need-to-know basis.
- Unsupervised work avoided for safety and security.
- Vacant secure areas locked and checked.
- Photography, video and recording devices restricted.
- Rules apply to third parties working in the area.

7.6 In practice

Data centre

The situation

Contractors work alone in the server hall during maintenance

Applying the control

- Escort required for all contractor work
- Phone cameras prohibited in the hall
- Hall locked and checked after each visit

Typical evidence

- Secure area rules
- Escort and visit logs
- Signage and checks

7.6 Two perspectives and common difficulties

Implementer's view

- Write simple secure-area rules
- Supervise third parties
- Restrict recording devices

Auditor's view

- Are rules known and followed?
- Are third parties supervised?
- Are vacant areas locked?

Common difficulties

- Lone contractors
- Photos of secure areas shared
- Rules not posted or explained

Connections: 7.1–7.2 perimeters and entry; 7.3 offices; 7.13 equipment maintenance.

MSM ACADEMY

S3.4.7 · A.7 PHYSICAL CONTROLS

A.7.7 Clear desk and clear screen

Annex A control

7.7

7.7 Clear desk and clear screen

What the control asks

Define and appropriately enforce clear desk rules for papers and removable storage media and clear screen rules for information processing facilities.

Purpose

Reduce the risks of unauthorized access to, loss of and damage to information on desks, screens and in other accessible locations during and outside normal working hours.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality

Cybersecurity concepts
Protect

Operational capabilities
Physical security

Security domains
Protection

7.7 What it means and how it is done

- Sensitive papers and media locked away when not in use.
- Screens locked when unattended; automatic lock timers.
- Printers: collect printouts promptly; secure printing where possible.
- Whiteboards wiped; documents removed from meeting rooms.
- Applies at home and in shared offices too.

7.7 In practice

Insurance

The situation

Claims files left on desks overnight in an open-plan office cleaned by contractors

Applying the control

- Lockable drawers issued
- Automatic screen lock after 5 minutes
- Monthly evening walk-round with feedback

Typical evidence

- Clear desk and screen policy
- Screen lock settings
- Walk-round results

7.7 Two perspectives and common difficulties

Implementer's view

- Provide lockable storage
- Enforce screen locks technically
- Check and give feedback

Auditor's view

- Walk the office: what is left out?
- Are screen locks enforced?
- Are printouts collected?

Common difficulties

- No storage provided
- Rules never checked
- Meeting rooms left with documents

Connections: 7.3 offices; 7.10 storage media; 8.1 endpoint devices; 6.3 awareness.

Lesson 3.8 recap

- 7.1–7.3: layered perimeters, controlled entry and secure offices
- 7.4: continuous monitoring that actually gets a response
- 7.5: protection from fire, flood, heat and other threats
- 7.6–7.7: rules for secure areas; clear desk and screen

Check your understanding

A server room has badge entry and cameras. Alarms trigger at night, but the alarm company only calls an office number nobody answers.

A 7.4 is met: cameras and alarms exist

B A gap in 7.4: monitoring must lead to detection and response

C Only a 7.2 entry issue

D Acceptable outside working hours

Check your understanding

A server room has badge entry and cameras. Alarms trigger at night, but the alarm company only calls an office number nobody answers.

A. 7.4 is met: cameras and alarms exist

B. A gap in 7.4: monitoring must lead to detection and response

C. Only a 7.2 entry issue

D. Acceptable outside working hours

Answer: B

7.4 aims to detect and deter. Alarms nobody responds to do neither; the response arrangement is part of the control.

MSM ACADEMY

SECTION 3 · LESSON 3.9

A.7 Equipment and media

3.9

Controls 7.8–7.14: siting equipment, assets off-premises, storage media, utilities, cabling, maintenance and disposal.

MSM ACADEMY

S3.4.8 · A.7 PHYSICAL CONTROLS

A.7.8 Equipment siting and protection

7.8

Annex A control

7.8 Equipment siting and protection

What the control asks

Site equipment securely and protect it.

Purpose

Reduce the risks from physical and environmental threats, and from unauthorized access and damage.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Physical security · Asset management

Security domains
Protection

7.8 What it means

- Equipment placed to minimize unnecessary access and overlooking.
- Protected from heat, water, dust, vibration, electrical interference.
- Environmental conditions monitored (temperature, humidity).
- Rules on eating and drinking near equipment.

7.8 Implementation guidance

- Site sensitive equipment away from public areas and windows.
- Protect against environmental threats: water, fire, temperature, dust.
- Monitor conditions in equipment rooms, with alerts.
- Protect equipment processing sensitive information from emanation where needed.
- Separate equipment managed by the organization from that of others.

7.8 In practice

Retail

The situation

A store’s network cabinet sits in the staff kitchen under a sink

Applying the control

- Cabinet moved to a locked storeroom
- Temperature sensor with alert added
- Kitchen kept equipment-free

Typical evidence

- Equipment location records
- Environmental monitoring logs
- Inspection results

7.8 Two perspectives and common difficulties

Implementer's view

- Choose locations by risk
- Monitor environmental conditions
- Inspect periodically

Auditor's view

- Where is critical equipment located?
- Are conditions monitored and alarmed?
- Any obvious hazards?

Common difficulties

- Equipment under pipes or in kitchens
- Unmonitored temperature
- Overlooked screens

Connections: 7.5 environmental threats; 7.11 utilities; 7.12 cabling; 7.13 maintenance.

MSM ACADEMY

S3.4.9 · A.7 PHYSICAL CONTROLS

A.7.9 Security of assets off-premises

7.9

Annex A control

7.9 Security of assets off-premises

What the control asks

Protect off-site assets.

Purpose

Prevent loss, damage, theft or compromise of off-site devices and interruption to the organization’s operations.

ISO/IEC 27002 attributes

Control type

Preventive

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Protect

Operational capabilities

Physical security · Asset management

Security domains

Protection

7.9 What it means and how it is done

- Covers laptops, phones, tablets and equipment used at home, travelling or at client sites.
- Users follow manufacturers’ and organizational protection rules.
- Devices not left unattended in public places or vehicles.
- A record of off-site equipment and who holds it.
- Personally owned devices used for work are included.

7.9 In practice

Field services

The situation

Engineers leave tablets in vans overnight; several are stolen

Applying the control

- Rule: devices removed from vehicles overnight
- Remote wipe enabled on all tablets
- Theft reported immediately as an incident

Typical evidence

- Off-site asset register
- Device management settings
- Loss and theft records

7.9 Two perspectives and common difficulties

Implementer's view

- Track off-site assets
- Enable remote wipe and encryption
- Give practical rules for travel

Auditor's view

- Is off-site equipment recorded?
- Can lost devices be wiped?
- Are losses reported?

Common difficulties

- No record of who holds what
- Unencrypted laptops
- Losses not reported

Connections: 6.7 remote working; 8.1 endpoint devices; 5.9 inventory; 8.24 cryptography.

MSM ACADEMY

S3.4.10 · A.7 PHYSICAL CONTROLS

A.7.10 Storage media

Annex A control

7.10

S3.4.10 · CONTROL 7.10

7.10 Storage media

What the control asks

Manage storage media through their life cycle of acquisition, use, transportation and disposal in accordance with the organization’s classification scheme and handling requirements.

Purpose

Ensure only authorized disclosure, modification, removal or destruction of information on storage media.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Physical security · Asset management

Security domains
Protection

7.10 What it means

- Storage media: USB drives, external disks, backup tapes, memory cards, paper too.
- Use is restricted by policy; encryption for sensitive data.
- Transport uses trusted methods and logs.
- Disposal is secure and recorded.

7.10 Implementation guidance

- Topic-specific policy on removable media; restrict use where not needed.
- Encrypt sensitive information on removable media.
- Keep media in safe storage according to classification.
- Use reliable couriers and records for transport.
- Dispose securely (shredding, degaussing, destruction) and keep records.

7.10 In practice

Laboratory

The situation

Instrument data copied to personal USB sticks for analysis at home

Applying the control

- USB storage blocked except on approved, encrypted drives
- Data transferred through a secure file service
- Old drives destroyed with certificates

Typical evidence

- Removable media policy
- Device control settings
- Destruction certificates

7.10 Two perspectives and common difficulties

Implementer's view

- Restrict removable media by default
- Encrypt what is allowed
- Record secure disposal

Auditor's view

- Are media controlled technically?
- Is sensitive data encrypted?
- Is disposal evidenced?

Common difficulties

- Unrestricted USB use
- Unencrypted backup media
- Media thrown away intact

Connections: 5.10 handling; 5.12 classification; 7.14 disposal; 8.10 deletion; 8.24 cryptography.

MSM ACADEMY

S3.4.11 · A.7 PHYSICAL CONTROLS

A.7.11 Supporting utilities

Annex A control

7.11

S3.4.11 · CONTROL 7.11

7.11 Supporting utilities

What the control asks

Protect information processing facilities from power failures and other disruptions caused by failures in supporting utilities.

Purpose

Prevent loss, damage or compromise of information and other associated assets, or interruption to operations, due to failure and disruption of supporting utilities.

ISO/IEC 27002 attributes

Control type
Preventive · Detective

Security properties
Integrity · Availability

Cybersecurity concepts
Protect · Detect

Operational capabilities
Physical security

Security domains
Protection

7.11 What it means

- Utilities: electricity, telecoms, water, gas, heating, ventilation and air conditioning.
- Capacity matches growth; equipment inspected and tested.
- Resilience: UPS, generators, multiple feeds, alarms.
- Emergency switches and lighting near exits.

7.11 Implementation guidance

- Assess dependence on each utility and set requirements.
- Provide UPS and generators for critical systems; test them under load.
- Monitor utilities with alarms (power, temperature, humidity).
- Maintain and inspect equipment per manufacturer guidance.
- Plan for capacity growth and diverse supply routes.

7.11 In practice

Call centre

The situation

A power cut lasts 20 minutes; the UPS fails after 5 because its batteries were never tested

Applying the control

- UPS batteries replaced and load-tested twice a year
- Generator added for critical systems
- Power alarms routed to the on-call team

Typical evidence

- Utility monitoring logs
- UPS and generator test records
- Maintenance contracts

7.11 Two perspectives and common difficulties

Implementer's view

- Identify critical utility dependencies
- Add resilience and alarms
- Test under realistic conditions

Auditor's view

- When was the UPS or generator last tested?
- Are alarms monitored?
- Is capacity sufficient?

Common difficulties

- Untested generators
- No cooling alarms
- Single points of failure

Connections: 7.5 environmental threats; 7.8 equipment siting; 8.14 redundancy; 5.30 ICT readiness.

MSM ACADEMY

S3.4.12 · A.7 PHYSICAL CONTROLS

A.7.12 Cabling security

Annex A control

7.12

S3.4.12 · CONTROL 7.12

7.12 Cabling security

What the control asks

Protect cables carrying power, data or supporting information services from interception, interference or damage.

Purpose

Prevent loss, damage, theft or compromise of information and other associated assets and interruption to the organization’s operations related to power and communications cabling.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Availability

Cybersecurity concepts
Protect

Operational capabilities
Physical security

Security domains
Protection

7.12 What it means and how it is done

- Cables run underground or in protected conduits where possible.
- Power and data cables separated to avoid interference.
- Patch panels and cable rooms locked; access controlled.
- Cables labelled and documented to avoid mistakes.
- For sensitive systems: armoured conduits, inspections, fibre.

7.12 In practice

Campus

The situation

Network cables between buildings run through an unlocked public underpass

Applying the control

- Cables moved into locked conduit
- Patch cabinets locked
- Cabling documented and labelled

Typical evidence

- Cabling diagrams
- Inspection records
- Access logs for cable rooms

7.12 Two perspectives and common difficulties

Implementer's view

- Protect cable routes physically
- Lock patch points
- Document and label

Auditor's view

- Are cable routes protected?
- Are patch cabinets locked?
- Is cabling documented?

Common difficulties

- Exposed cables in public areas
- Unlocked patch cabinets
- Undocumented cabling

Connections: 7.8 equipment siting; 7.11 utilities; 8.20 network security.

S3.4.13 · A.7 PHYSICAL CONTROLS

A.7.13 Equipment maintenance

Annex A control

7.13

S3.4.13 · CONTROL 7.13

7.13 Equipment maintenance

What the control asks

Maintain equipment correctly to ensure availability, integrity and confidentiality of information.

Purpose

Prevent loss, damage, theft or compromise of information and other associated assets and interruption to operations caused by lack of maintenance.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Physical security · Asset management

Security domains
Protection · Resilience

7.13 What it means and how it is done

- Maintenance follows supplier-recommended intervals and specifications.
- Only authorized personnel carry out repairs.
- Records of faults and maintenance are kept.
- Sensitive data protected when equipment goes off-site for repair.
- Equipment checked after maintenance before returning to use.

7.13 In practice

Printing services

The situation

Multifunction printers with internal disks sent for repair with scanned documents still stored

Applying the control

- Disks wiped or removed before off-site repair
- Maintenance by authorized technicians only
- Service log kept per device

Typical evidence

- Maintenance schedule and logs
- Authorized supplier list
- Data removal records

7.13 Two perspectives and common difficulties

Implementer's view

- Schedule maintenance per supplier guidance
- Protect data before repair
- Check equipment after maintenance

Auditor's view

- Is maintenance on schedule?
- Who performs it?
- Is data removed before off-site repair?

Common difficulties

- Maintenance only when something breaks
- Data left on devices sent away
- Unsupervised technicians

Connections: 7.6 working in secure areas; 7.14 disposal or re-use; 8.10 deletion; 5.21 ICT supply chain.

MSM ACADEMY

S3.4.14 · A.7 PHYSICAL CONTROLS

A.7.14 Secure disposal or re-use of equipment

7.14

Annex A control

7.14 Secure disposal or re-use of equipment

What the control asks

Verify items of equipment containing storage media to ensure that any sensitive data and licensed software has been removed or securely overwritten prior to disposal or re-use.

Purpose

Prevent leakage of information from equipment to be disposed or re-used.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality

Cybersecurity concepts
Protect

Operational capabilities
Physical security · Asset management

Security domains
Protection

7.14 What it means and how it is done

- Applies to computers, phones, printers, network devices and anything with storage.
- Methods: secure erasure, cryptographic erasure, physical destruction.
- Verification that the method worked.
- Damaged devices assessed: repair, or destroy.
- Third-party disposal services under contract, with certificates.

7.14 In practice

School

The situation

Old laptops donated to a charity with student records still on them

Applying the control

- All devices wiped with a verified tool before donation
- Disposal contractor issues certificates for destroyed disks
- Disposal log matched to the asset inventory

Typical evidence

- Disposal procedure
- Wipe verification reports
- Destruction certificates
- Updated inventory

7.14 Two perspectives and common difficulties

Implementer's view

- Define approved erasure and destruction methods
- Verify every device
- Reconcile disposal with the inventory

Auditor's view

- Pick a disposed asset: what evidence exists?
- Are contractors certified and contracted?
- Are printers and phones included?

Common difficulties

- Simple deletion instead of secure erasure
- Printers and phones forgotten
- No verification

Connections: 7.10 storage media; 7.13 maintenance; 8.10 information deletion; 5.9 inventory; 5.11 return of assets.

LESSON 3.9 · RECAP

Lesson 3.9 recap

- 7.8–7.9: equipment sited and protected; off-site assets secured
- 7.10: storage media managed through their life cycle
- 7.11–7.12: resilient utilities and protected cabling
- 7.13–7.14: maintenance done properly; data verified gone before disposal

Check your understanding

Old office printers are returned to the leasing company. Nobody checks their internal hard drives.

A No issue: printers are not computers

B A gap against 7.14: equipment with storage must be verified clean before disposal or re-use

C Only a supplier issue under 5.19

D Acceptable if the lease contract is standard

Check your understanding

Old office printers are returned to the leasing company. Nobody checks their internal hard drives.

A. No issue: printers are not computers

B. A gap against 7.14: equipment with storage must be verified clean before disposal or re-use

C. Only a supplier issue under 5.19

D. Acceptable if the lease contract is standard

Answer: B

7.14 covers any equipment containing storage media. Printer disks often hold copies of scanned and printed documents.

MSM ACADEMY

SECTION 3 · LESSON 3.10

A.8 Endpoints, access and authentication

3.10

Controls 8.1–8.5: user endpoint devices, privileged access, access restriction, source code access and secure authentication.

S3.5.1 · A.8 TECHNOLOGICAL CONTROLS

A.8.1 User end point devices

Annex A control

8.1

S3.5.1 · CONTROL 8.1

8.1 User end point devices

What the control asks

Protect information stored on, processed by or accessible via user endpoint devices.

Purpose

Protect information against the risks introduced by using user endpoint devices.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Asset management · Information protection

Security domains
Protection

8.1 What it means

- A topic-specific policy covers configuration and handling of endpoints.
- Covers organization-owned and personal devices (BYOD).
- Risks: loss, theft, malware, unpatched software, unauthorized software, data leakage.
- Endpoints are often the attacker’s first foothold.

8.1 Implementation guidance (1 of 2)

- Register devices; manage them centrally (e.g. mobile device management).
- Encrypt storage; enforce screen lock and strong authentication.
- Keep software updated; restrict software installation (8.19).
- Protect against malware (8.7).

8.1 Implementation guidance (2 of 2)

- For BYOD: separate work and personal data; agree terms including remote wipe of work data.
- Control backup, cloud sync and removable media from endpoints.
- Allow remote locate, lock and wipe for lost devices.
- Educate users on endpoint risks.

8.1 In practice

Engineering firm

The situation

- A lost laptop held unencrypted client designs
- Half the laptops miss security updates

Applying the control

- All laptops enrolled in central management
- Full-disk encryption and automatic updates enforced
- Remote lock and wipe enabled

Typical evidence

- Endpoint policy
- Device management compliance reports
- Lost device records

8.1 Two perspectives and common difficulties

Implementer's view

- Manage every device that touches work data
- Encrypt and patch endpoints
- Separate work data on personal devices

Auditor's view

- What share of devices is managed and compliant?
- How are personal devices controlled?
- What happens when a device is lost?

Common difficulties

- Unmanaged personal devices
- Unencrypted laptops
- Endpoints missing updates

Connections: 6.7 remote working; 7.9 off-site assets; 8.7 malware; 8.8 vulnerabilities; 8.19 software installation; 8.24 cryptography.

MSM ACADEMY

S3.5.2 · A.8 TECHNOLOGICAL CONTROLS

A.8.2 Privileged access rights

Annex A control

8.2

8.2 Privileged access rights

What the control asks

Restrict and manage the allocation and use of privileged access rights.

Purpose

Ensure only authorized users, software components and services are provided with privileged access rights.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Identity and access management

Security domains
Protection

8.2 What it means

- Privileged rights can override controls; they need tighter management.
- Allocated per need, per event where possible, through an authorization process.
- Separate privileged accounts from everyday accounts.
- Privileged use is logged and reviewed.

8.2 Implementation guidance (1 of 2)

- Identify privileged access for each system and who needs it.
- Authorize and record allocation; set expiry where possible.
- Use separate identities for privileged work.
- Require strong (multi-factor) authentication.

8.2 Implementation guidance (2 of 2)

- Prefer just-in-time or time-limited elevation.
- Log and monitor privileged activity; protect the logs.
- Review privileged rights more frequently than normal rights.
- Avoid generic administrator accounts; control any that must exist.

8.2 In practice

Retail

The situation

Thirty IT staff share the domain administrator account

Applying the control

- Named admin accounts, separate from daily accounts
- Just-in-time elevation with approval
- Privileged sessions logged; reviews monthly

Typical evidence

- List of privileged users and approvals
- Privileged access management logs
- Monthly review records

8.2 Two perspectives and common difficulties

Implementer's view

- Minimize standing privilege
- Separate admin and daily accounts
- Log and review privileged use

Auditor's view

- Who holds privileged rights, and why?
- Are generic admin accounts controlled?
- Is privileged activity reviewed?

Common difficulties

- Shared admin accounts
- Admin rights for convenience
- Privileged logs nobody reviews

Connections: 5.15 access rules; 5.18 access rights; 5.3 segregation; 8.5 authentication; 8.15 logging; 8.18 privileged utilities.

MSM ACADEMY

S3.5.3 · A.8 TECHNOLOGICAL CONTROLS

A.8.3 Information access restriction

Annex A control



8.3 Information access restriction

What the control asks

Restrict access to information and other associated assets in accordance with the established topic-specific policy on access control.

Purpose

Ensure only authorized access and prevent unauthorized access to information and other associated assets.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Identity and access management

Security domains
Protection

8.3 What it means

- Systems enforce the access rules from 5.15.
- Access controlled at the level of data, functions and outputs.
- No anonymous access to sensitive information.
- Dynamic access management for high-value information where needed.

8.3 Implementation guidance

- Configure systems to enforce need-to-know.
- Control read, write, delete and execute rights.
- Limit information in outputs and exports.
- Isolate sensitive applications or data where needed.
- Consider dynamic controls: rights management, conditional access.

8.3 In practice

Healthcare

The situation

Every hospital user can search the full patient index

Applying the control

- Access restricted to patients under the user’s care
- “Break-glass” emergency access logged and reviewed
- Exports limited by role

Typical evidence

- System access configuration
- Break-glass logs and reviews
- Export permission settings

8.3 Two perspectives and common difficulties

Implementer's view

- Enforce rules in system configuration
- Control outputs, not just screens
- Log exceptional access

Auditor's view

- Do system permissions match the rules?
- Can users export more than they should?
- Is emergency access reviewed?

Common difficulties

- Broad default permissions
- Uncontrolled exports
- Anonymous or shared access

Connections: 5.15 access rules; 5.18 access rights; 8.2 privileged access; 8.11 data masking; 8.12 data leakage prevention.

MSM ACADEMY

S3.5.4 · A.8 TECHNOLOGICAL CONTROLS

A.8.4 Access to source code

Annex A control

8.4

8.4 Access to source code

What the control asks

Appropriately manage read and write access to source code, development tools and software libraries.

Purpose

Prevent the introduction of unauthorized functionality, avoid unintentional or malicious changes and maintain the confidentiality of valuable intellectual property.

ISO/IEC 27002 attributes

Control type

Preventive

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Protect

Operational capabilities

Identity and access management · Application security · Secure configuration

Security domains

Protection

8.4 What it means

- Source code is stored in managed repositories.
- Read and write access granted per need; write access tightly controlled.
- Changes go through change control and review.
- Access is logged; secrets are not stored in code.

8.4 Implementation guidance

- Use a source code management system with access control.
- Protect main branches: required reviews, no direct pushes.
- Grant write access by project and role; review regularly.
- Log access and changes; protect logs.
- Scan for secrets in repositories; remove and rotate any found.

8.4 In practice

Software

The situation

All 200 developers can push directly to any product’s main branch

Applying the control

- Write access limited to project teams
- Main branch protected with mandatory review
- Secret scanning enabled

Typical evidence

- Repository access settings
- Branch protection rules
- Review records and scan results

8.4 Two perspectives and common difficulties

Implementer's view

- Restrict write access by project
- Protect main branches
- Keep secrets out of code

Auditor's view

- Who can change production code?
- Are reviews enforced technically?
- Are secrets found in repositories?

Common difficulties

- Organization-wide write access
- Unprotected main branches
- Hard-coded credentials

Connections: 8.25–8.28 secure development and coding; 8.32 change management; 5.32 intellectual property; 8.31 environment separation.

MSM ACADEMY

S3.5.5 · A.8 TECHNOLOGICAL CONTROLS

A.8.5 Secure authentication

Annex A control



8.5 Secure authentication

What the control asks

Implement secure authentication technologies and procedures based on information access restrictions and the topic-specific policy on access control.

Purpose

Ensure a user or an entity is securely authenticated when access to systems, applications and services is granted.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Identity and access management

Security domains
Protection

8.5 What it means

- Strength of authentication matches the classification of what is accessed.
- Multi-factor authentication for sensitive or remote access.
- Secure log-on procedures: minimal information shown, limits on failed attempts.
- Protection of authentication data in transit and storage.

8.5 Implementation guidance (1 of 2)

- Choose authentication methods by risk; MFA for sensitive and remote access.
- Do not display system details before successful log-on.
- Validate credentials only when all input is complete; give generic errors.

8.5 Implementation guidance (2 of 2)

- Limit failed attempts; log successful and failed log-ons.
- Never transmit passwords in clear text.
- Terminate inactive sessions; restrict connection times for high-risk apps.
- Consider risk-based or passwordless authentication.

8.5 In practice

Public sector

The situation

A tax agency portal accepts password-only log-in for citizens and staff

Applying the control

- MFA for staff remote access and admin portals
- Risk-based step-up for citizens changing bank details
- Account lockout and log-on monitoring

Typical evidence

- Authentication standards by system
- MFA coverage reports
- Log-on monitoring alerts

8.5 Two perspectives and common difficulties

Implementer's view

- Match authentication strength to risk
- Enforce MFA where it matters
- Monitor log-on activity

Auditor's view

- Where is MFA required, and enforced?
- Are log-on attempts limited and logged?
- Are legacy systems exempt?

Common difficulties

- MFA optional or with exceptions
- Legacy systems with weak log-on
- Verbose error messages

Connections: 5.17 authentication information; 8.2 privileged access; 8.3 access restriction; 8.15 logging; 8.24 cryptography.

LESSON 3.10 · RECAP

Lesson 3.10 recap

- 8.1: endpoints managed, encrypted and patched, including personal devices
- 8.2: privileged access minimized, separated and monitored
- 8.3–8.4: access enforced technically; source code protected
- 8.5: authentication strength matched to risk, with MFA where it matters

Check your understanding

Administrators use their everyday accounts, with permanent admin rights, for email and for server administration.

A Acceptable if passwords are strong

B A gap against 8.2: privileged rights should be separate, minimized and monitored

C Only an 8.5 authentication issue

D Required for efficient administration

Check your understanding

Administrators use their everyday accounts, with permanent admin rights, for email and for server administration.

A. Acceptable if passwords are strong

B. A gap against 8.2: privileged rights should be separate, minimized and monitored

C. Only an 8.5 authentication issue

D. Required for efficient administration

Answer: B

8.2 calls for separate privileged identities and minimal standing privilege. Admin rights on an email account expose them to phishing.

MSM ACADEMY

SECTION 3 · LESSON 3.11

A.8 Operations and data protection

3.11

Controls 8.6–8.14: capacity, malware, vulnerabilities, configuration, deletion, masking, leakage prevention, backup and redundancy.

MSM ACADEMY

S3.5.6 · A.8 TECHNOLOGICAL CONTROLS

A.8.6 Capacity management

Annex A control



8.6 Capacity management

What the control asks

Monitor and adjust the use of resources in line with current and expected capacity requirements.

Purpose

Ensure the required capacity of information processing facilities, human resources, offices and other facilities.

ISO/IEC 27002 attributes

Control type
Preventive · Detective

Security properties
Integrity · Availability

Cybersecurity concepts
Identify · Protect · Detect

Operational capabilities
Continuity

Security domains
Governance and Ecosystem · Protection

8.6 What it means

- Capacity covers systems (storage, processing, network), people and facilities.
- Current use is monitored; future needs are forecast.
- Both increasing capacity and reducing demand are options.
- Capacity plans consider business plans and new systems.

8.6 Implementation guidance

- Identify capacity requirements for critical systems and services.
- Monitor use, with alerts before thresholds are reached.
- Forecast demand using business plans and trends.
- Plan increases with lead times; consider cloud elasticity.
- Reduce demand: archive, delete obsolete data, decommission, optimize.

8.6 In practice

E-commerce

The situation

A shop’s site slows to a halt during a seasonal sale

Applying the control

- Load forecasts from marketing plans
- Auto-scaling with tested limits
- Alerts at 70% capacity

Typical evidence

- Capacity plans and forecasts
- Monitoring dashboards and alerts
- Records of capacity changes

8.6 Two perspectives and common difficulties

Implementer's view

- Monitor and alert before limits
- Forecast from business plans
- Manage demand as well as supply

Auditor's view

- Are critical systems monitored for capacity?
- Are forecasts linked to business plans?
- Any recent capacity incidents?

Common difficulties

- Monitoring without thresholds
- Growth not forecast
- People capacity ignored

Connections: 8.14 redundancy; 8.16 monitoring; 5.30 ICT readiness; 8.32 change management.

MSM ACADEMY

S3.5.7 · A.8 TECHNOLOGICAL CONTROLS

A.8.7 Protection against malware

8.7

Annex A control

S3.5.7 · CONTROL 8.7

8.7 Protection against malware

What the control asks

Implement protection against malware, supported by appropriate user awareness.

Purpose

Ensure information and other associated assets are protected against malware.

ISO/IEC 27002 attributes

Control type

Preventive · Detective · Corrective

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Protect · Detect

Operational capabilities

System and network security · Information protection

Security domains

Protection · Defence

8.7 What it means

- Detection and repair software alone is not enough.
- Combine technical controls, access controls, change management and awareness.
- Prevent unauthorized software and known malicious sites.
- Prepare to recover from malware incidents.

8.7 Implementation guidance (1 of 2)

- Deploy and update anti-malware on endpoints and servers.
- Scan files, email, downloads and removable media.
- Block known malicious sites and file types.
- Use application allow-listing where practical.

8.7 Implementation guidance (2 of 2)

- Restrict installation of software (8.19) and admin rights (8.2).
- Patch vulnerabilities that malware exploits (8.8).
- Train users to recognize phishing and suspicious files.
- Plan recovery: backups, isolation, business continuity.

8.7 In practice

School district

The situation

Ransomware enters through a phishing email; staff are local administrators

Applying the control

- Endpoint protection with central alerts
- Admin rights removed; allow-listing for school devices
- Phishing training for staff
- Offline backups for recovery

Typical evidence

- Anti-malware coverage reports
- Detection alerts and responses
- Training records
- Backup tests

8.7 Two perspectives and common difficulties

Implementer's view

- Layer technical and human defences
- Remove the privileges malware needs
- Prepare to recover

Auditor's view

- Is protection on all devices and up to date?
- How are alerts handled?
- Can the organization recover?

Common difficulties

- Relying on antivirus alone
- Alerts nobody reviews
- Users with admin rights

Connections: 8.1 endpoints; 8.2 privileged access; 8.8 vulnerabilities; 8.19 software installation; 8.23 web filtering; 6.3 awareness; 8.13 backup.

MSM ACADEMY

S3.5.8 · A.8 TECHNOLOGICAL CONTROLS

A.8.8 Management of technical vulnerabilities

8.8

Annex A control

S3.5.8 · CONTROL 8.8

8.8 Management of technical vulnerabilities

What the control asks

Obtain information about technical vulnerabilities of information systems in use, evaluate the organization’s exposure to such vulnerabilities, and take appropriate measures.

Purpose

Prevent exploitation of technical vulnerabilities.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Identify · Protect

Operational capabilities
Threat and vulnerability management

Security domains
Governance and Ecosystem · Protection · Defence

8.8 What it means

- Requires an accurate asset and software inventory.
- Information comes from vendors, advisories, scanning and testing.
- Exposure is evaluated: does it affect us, and how badly?
- Measures: patching, configuration changes, compensating controls.

8.8 Implementation guidance (1 of 2)

- Maintain an inventory of software, versions and owners.
- Define roles for monitoring, assessing and fixing vulnerabilities.
- Subscribe to relevant sources; scan regularly.
- Prioritize by severity, exposure and asset criticality.

8.8 Implementation guidance (2 of 2)

- Set remediation timelines by priority; test patches before wide deployment.
- Apply compensating controls when no patch exists.
- Track remediation; report overdue items.
- Address cloud and supplier-managed components too.

8.8 In practice

Hospital

The situation

Critical vulnerabilities in internet-facing systems stay open for months

Applying the control

- Weekly scanning; critical internet-facing fixes within 7 days
- Medical devices that cannot be patched isolated on separate networks
- Overdue items reported to management

Typical evidence

- Vulnerability scan reports
- Remediation tracker with timelines
- Exception and compensating-control records

8.8 Two perspectives and common difficulties

Implementer's view

- Know your software inventory
- Prioritize by exposure and severity
- Track to closure; handle exceptions

Auditor's view

- How quickly are critical vulnerabilities fixed?
- Are exceptions approved with compensating controls?
- Is the inventory complete?

Common difficulties

- Scanning without remediation
- Unknown software
- Unpatchable systems left exposed

Connections: 5.9 inventory; 5.7 threat intelligence; 8.9 configuration; 8.19 software installation; 8.32 change management; 5.21 ICT supply chain.

MSM ACADEMY

S3.5.9 · A.8 TECHNOLOGICAL CONTROLS

A.8.9 Configuration management

8.9

Annex A control · New in 2022

S3.5.9 · CONTROL 8.9

8.9 Configuration management

NEW IN 2022

What the control asks

Establish, document, implement, monitor and review configurations, including security configurations, of hardware, software, services and networks.

Purpose

Ensure hardware, software, services and networks function correctly with required security settings, and configuration is not altered by unauthorized or incorrect changes.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Secure configuration

Security domains
Protection

8.9 What it means

- Secure baselines (templates) for each type of system.
- Based on vendor guidance and recognized benchmarks.
- Changes to configuration go through change management.
- Configurations are monitored for drift and reviewed.

8.9 Implementation guidance (1 of 2)

- Define standard secure templates for each system type.
- Base them on hardening guides; remove unnecessary services and accounts.
- Change default passwords and settings.

8.9 Implementation guidance (2 of 2)

- Record configurations and changes; protect configuration records.
- Monitor for deviation from baselines; correct drift.
- Review templates when threats or vendors’ guidance change.
- Include cloud service and network device configurations.

8.9 In practice

Cloud-native startup

The situation

Each engineer configures cloud resources by hand; settings vary widely

Applying the control

- Infrastructure-as-code templates with security settings
- Automated checks against a cloud security benchmark
- Drift alerts and periodic review

Typical evidence

- Baseline templates
- Configuration compliance reports
- Change records for configuration

8.9 Two perspectives and common difficulties

Implementer's view

- Define baselines per system type
- Automate configuration and checks
- Route changes through change management

Auditor's view

- Are baselines defined and applied?
- How is drift detected?
- Are defaults changed?

Common difficulties

- No baselines
- Manual changes outside change control
- Default credentials left in place

Connections: 8.8 vulnerabilities; 8.32 change management; 5.23 cloud; 8.20–8.22 networks; 8.1 endpoints.

MSM ACADEMY

S3.5.10 · A.8 TECHNOLOGICAL CONTROLS

A.8.10 Information deletion

Annex A control · New in 2022

8.10

S3.5.10 · CONTROL 8.10

8.10 Information deletion

NEW IN 2022

What the control asks

Delete information stored in information systems, devices or any other storage media when no longer required.

Purpose

Prevent unnecessary exposure of sensitive information and comply with legal, statutory, regulatory and contractual requirements for information deletion.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality

Cybersecurity concepts
Protect

Operational capabilities
Information protection · Legal and compliance

Security domains
Protection

8.10 What it means

- Information kept longer than needed is a liability.
- Deletion follows retention rules (5.33) and privacy law (5.34).
- Methods match sensitivity: secure deletion, crypto-erasure.
- Covers cloud services and suppliers, with evidence of deletion.

8.10 Implementation guidance

- Define when information must be deleted, by type.
- Use approved deletion methods by sensitivity; automate where possible.
- Delete obsolete copies and backups in line with retention.
- Obtain deletion evidence from cloud providers and suppliers.
- Record deletions where required.

8.10 In practice

Recruitment agency

The situation

Candidate CVs kept indefinitely across email and shared drives

Applying the control

- Retention rule: delete 12 months after last contact
- Automated deletion in the recruitment system
- Supplier confirms deletion at contract end

Typical evidence

- Deletion rules
- Automated deletion logs
- Supplier deletion certificates

8.10 Two perspectives and common difficulties

Implementer's view

- Link deletion to retention rules
- Automate where possible
- Get evidence from providers

Auditor's view

- Is information deleted on schedule?
- Are copies and backups covered?
- Is there evidence from suppliers?

Common difficulties

- Keeping everything forever
- Copies forgotten
- No evidence from cloud providers

Connections: 5.33 records; 5.34 privacy; 7.14 disposal; 7.10 storage media; 5.23 cloud.

MSM ACADEMY

S3.5.11 · A.8 TECHNOLOGICAL CONTROLS

A.8.11 Data masking

Annex A control · New in 2022

8.11

S3.5.11 · CONTROL 8.11

8.11 Data masking

NEW IN 2022

What the control asks

Use data masking in accordance with the organization’s topic-specific policy on access control and other related policies, and business requirements, taking applicable legislation into consideration.

Purpose

Limit the exposure of sensitive data including PII, and comply with legal, statutory, regulatory and contractual requirements.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality

Cybersecurity concepts
Protect

Operational capabilities
Information protection

Security domains
Protection

8.11 What it means

- Masking hides some or all of sensitive data from those who do not need it.
- Techniques: pseudonymization, anonymization, encryption, nulling, substitution, hashing.
- Common uses: test data, analytics, support screens.
- Anonymized data must not be re-identifiable.

8.11 Implementation guidance (1 of 2)

- Identify where sensitive data is exposed beyond need.
- Choose masking techniques by purpose and risk.
- Pseudonymized data remains personal data; protect the keys.

8.11 Implementation guidance (2 of 2)

- Test anonymization against re-identification by combining fields.
- Restrict access to unmasked data and to masking keys.
- Consider legal requirements on anonymization.
- Review masking when data use or fields change.

8.11 In practice

Bank

The situation

Developers test with a full copy of production customer data

Applying the control

- Test data pseudonymized; names and account numbers substituted
- Key held by the data team only
- Support screens show only last four digits

Typical evidence

- Masking procedure
- Masked test data samples
- Access records for unmasked data and keys

8.11 Two perspectives and common difficulties

Implementer's view

- Mask by default outside production
- Protect keys and unmasked sources
- Test for re-identification

Auditor's view

- Where is unmasked data used, and why?
- Is anonymization tested?
- Who can access keys?

Common difficulties

- Production data in test
- Weak anonymization that combined fields can re-identify
- Keys stored with the data

Connections: 5.34 privacy; 8.3 access restriction; 8.33 test information; 8.24 cryptography; 8.12 data leakage prevention.

MSM ACADEMY

S3.5.12 · A.8 TECHNOLOGICAL CONTROLS

A.8.12 Data leakage prevention

8.12

Annex A control · New in 2022

S3.5.12 · CONTROL 8.12

8.12 Data leakage prevention

NEW IN 2022

What the control asks

Apply data leakage prevention measures to systems, networks and any other devices that process, store or transmit sensitive information.

Purpose

Detect and prevent the unauthorized disclosure and extraction of information by individuals or systems.

ISO/IEC 27002 attributes

Control type
Preventive · Detective

Security properties
Confidentiality

Cybersecurity concepts
Protect · Detect

Operational capabilities
Information protection

Security domains
Protection · Defence

8.12 What it means

- Identify and classify sensitive information first (5.12).
- Monitor channels: email, web uploads, removable media, cloud, printing.
- Act: block, alert, quarantine or require justification.
- Balance protection with privacy and usability.

8.12 Implementation guidance (1 of 2)

- Identify sensitive information and where it resides.
- Identify leakage channels and their risks.
- Choose measures: DLP tools, blocking uploads, restricting copying.

8.12 Implementation guidance (2 of 2)

- Tune rules to reduce false positives; start in monitor mode.
- Define how alerts are handled and by whom.
- Respect privacy laws in monitoring employees.
- Review effectiveness and adjust.

8.12 In practice

Defence supplier

The situation

Engineers upload design files to personal cloud storage to work from home

Applying the control

- Uploads of labelled files to unapproved cloud blocked
- USB copying of labelled files blocked
- Alerts reviewed daily by security

Typical evidence

- DLP policy and rule set
- Alert records and handling
- Rule tuning history

8.12 Two perspectives and common difficulties

Implementer's view

- Start from classified data
- Cover the main leakage channels
- Tune before blocking

Auditor's view

- Which channels are covered?
- How are alerts handled?
- Is monitoring lawful?

Common difficulties

- Tools in monitor mode forever
- Alert fatigue
- Classification missing, so rules cannot work

Connections: 5.12–5.13 classification and labelling; 5.14 transfer; 7.10 storage media; 8.11 masking; 8.16 monitoring; 5.34 privacy.

MSM ACADEMY

S3.5.13 · A.8 TECHNOLOGICAL CONTROLS

A.8.13 Information backup

Annex A control

8.13

S3.5.13 · CONTROL 8.13

8.13 Information backup

What the control asks

Maintain backup copies of information, software and systems and test them regularly in accordance with the agreed topic-specific policy on backup.

Purpose

Enable recovery from loss of data or systems.

ISO/IEC 27002 attributes

Control type
Corrective

Security properties
Integrity · Availability

Cybersecurity concepts
Recover

Operational capabilities
Continuity

Security domains
Protection

8.13 What it means

- A topic-specific backup policy sets scope, frequency and retention.
- Backups meet recovery objectives (RPO) from continuity planning.
- Copies are protected and stored separately, e.g. offline or immutable.
- Restores are tested regularly to prove recovery works.

8.13 Implementation guidance (1 of 2)

- Define scope: data, systems, configurations, cloud services.
- Set frequency and retention by business need and recovery objectives.
- Protect backups: encryption, access control, separation.

8.13 Implementation guidance (2 of 2)

- Keep at least one copy offline or immutable against ransomware.
- Test restores regularly, including full system recovery where needed.
- Monitor backup jobs; investigate failures.
- Check what cloud and SaaS providers back up, and what they do not.

8.13 In practice

Accounting firm

The situation

- Backups are written to a server on the same network
- Ransomware encrypts both production and backups

Applying the control

- Immutable cloud backup added
- Daily backups with 30-day retention
- Quarterly restore tests of client files and the accounting system

Typical evidence

- Backup policy
- Job monitoring reports
- Restore test records
- Immutability settings

8.13 Two perspectives and common difficulties

Implementer's view

- Derive frequency from recovery objectives
- Keep an offline or immutable copy
- Test restores

Auditor's view

- When was the last restore test, and did it succeed?
- Are backups protected from ransomware?
- Are failed jobs investigated?

Common difficulties

- Backups on the same network
- Never testing restores
- Assuming SaaS providers back up your data

Connections: 5.29–5.30 continuity; 8.14 redundancy; 8.7 malware; 5.33 records; 8.10 deletion; 8.24 cryptography.

MSM ACADEMY

S3.5.14 · A.8 TECHNOLOGICAL CONTROLS

A.8.14 Redundancy of information processing facilities

8.14

Annex A control

S3.5.14 · CONTROL 8.14

8.14 Redundancy of information processing facilities

What the control asks

Implement information processing facilities with redundancy sufficient to meet availability requirements.

Purpose

Ensure the continuous operation of information processing facilities.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Availability

Cybersecurity concepts
Protect

Operational capabilities
Continuity · Asset management

Security domains
Protection · Resilience

8.14 What it means and how it is done

- Redundancy: duplicate components, systems, networks or sites.
- Driven by availability requirements from the business.
- Redundant components must be independent: no shared single point of failure.
- Failover is tested.
- Suppliers and cloud regions are part of the design.

8.14 In practice

Payment processor

The situation

Two servers, but both behind one firewall and one internet line

Applying the control

- Second firewall and diverse internet provider added
- Active-active setup across two sites
- Failover tested twice a year

Typical evidence

- Availability requirements
- Architecture diagrams showing redundancy
- Failover test records

8.14 Two perspectives and common difficulties

Implementer's view

- Design from availability requirements
- Remove hidden single points of failure
- Test failover

Auditor's view

- What are the availability requirements?
- Are there single points of failure?
- When was failover last tested?

Common difficulties

- Redundant servers behind one shared component
- Untested failover
- Requirements never defined

Connections: 5.30 ICT readiness; 8.6 capacity; 8.13 backup; 7.11 utilities; 5.23 cloud.

Lesson 3.11 recap

- 8.6–8.8: capacity, malware and vulnerabilities managed continuously
- 8.9: secure configuration baselines, monitored for drift
- 8.10–8.12: delete, mask and prevent leakage of sensitive data
- 8.13–8.14: tested backups and real redundancy

Check your understanding

A research team receives an “anonymized” patient dataset. Birth date, gender and home town remain, and many records are unique.

A Conforming: names were removed

B A concern under 8.11: the combination of fields may allow re-identification

C Only a test-data issue under 8.33

D Acceptable because only researchers see it

Check your understanding

A research team receives an “anonymized” patient dataset. Birth date, gender and home town remain, and many records are unique.

A. Conforming: names were removed

B. A concern under 8.11: the combination of fields may allow re-identification

C. Only a test-data issue under 8.33

D. Acceptable because only researchers see it

Answer: B

8.11 expects anonymization that resists re-identification. Unique combinations of fields can identify people even without names.

MSM ACADEMY

SECTION 3 · LESSON 3.12

A.8 Logging, monitoring and networks

3.12

Controls 8.15–8.23: logging, monitoring, clocks, utility programs, software installation, network security, network services, segregation and web filtering.

MSM ACADEMY

S3.5.15 · A.8 TECHNOLOGICAL CONTROLS

A.8.15 Logging

Annex A control



S3.5.15 · CONTROL 8.15

8.15 Logging

What the control asks

Produce, store, protect and analyse logs that record activities, exceptions, faults and other relevant events.

Purpose

Record events, generate evidence, ensure the integrity of log information, prevent unauthorized access, identify events that can lead to an incident, and support investigations.

ISO/IEC 27002 attributes

Control type
Detective

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Detect

Operational capabilities
Information security event management

Security domains
Protection · Defence

8.15 What it means

- Decide what to log, based on risk.
- Typical content: user IDs, activities, dates and times, devices, success and failure.
- Logs are protected against tampering and deletion, including by administrators.
- Logs are retained as long as needed and analysed.

8.15 Implementation guidance (1 of 2)

- Define logging requirements per system by risk.
- Log successful and failed access, privileged actions, changes, alarms.
- Synchronize clocks (8.17) for correlation.

8.15 Implementation guidance (2 of 2)

- Centralize logs; protect integrity (write-once, hashing) and restrict access.
- Set retention to meet investigation and legal needs.
- Analyse logs regularly, ideally with automated correlation (SIEM).
- Respect privacy: logs can contain personal data.

8.15 In practice

University

The situation

- Logs kept only on each server, overwritten after 7 days
- An investigation finds no trace of a past intrusion

Applying the control

- Central log platform with 12-month retention
- Administrators cannot delete central logs
- Automated alerts on key events

Typical evidence

- Logging standard
- Central log configuration and retention
- Access controls on logs
- Analysis reports

8.15 Two perspectives and common difficulties

Implementer's view

- Log by risk
- Centralize and protect logs
- Analyse, do not just store

Auditor's view

- What is logged on critical systems?
- Can administrators alter logs?
- Is retention sufficient for investigations?

Common difficulties

- Logging disabled or too short
- Logs nobody reviews
- Administrators able to erase their traces

Connections: 8.16 monitoring; 8.17 clocks; 5.28 evidence; 8.2 privileged access; 5.25 event assessment.

MSM ACADEMY

S3.5.16 · A.8 TECHNOLOGICAL CONTROLS

A.8.16 Monitoring activities

Annex A control · New in 2022

8.16

S3.5.16 · CONTROL 8.16

8.16 Monitoring activities

NEW IN 2022

What the control asks

Monitor networks, systems and applications for anomalous behaviour and take appropriate actions to evaluate potential information security incidents.

Purpose

Detect anomalous behaviour and potential information security incidents.

ISO/IEC 27002 attributes

Control type
Detective · Corrective

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Detect · Respond

Operational capabilities
Information security event management

Security domains
Defence

8.16 What it means

- Requires a baseline of normal behaviour to spot anomalies.
- Monitors traffic, access, system use, alerts from security tools.
- Real-time or periodic, depending on risk.
- Anomalies go to event assessment (5.25).

8.16 Implementation guidance (1 of 2)

- Establish baselines of normal activity.
- Monitor inbound and outbound traffic, access patterns and critical system use.
- Use detection tools: SIEM, intrusion detection, endpoint detection and response.

8.16 Implementation guidance (2 of 2)

- Define alert thresholds and who responds, including out of hours.
- Tune to reduce false positives; review regularly.
- Feed threat intelligence (5.7) into detection rules.
- Record monitoring results and actions.

8.16 In practice

Logistics

The situation

An attacker exfiltrates data over weeks; nobody notices unusual outbound traffic

Applying the control

- Baseline of normal outbound volumes
- Alerts on large or unusual transfers
- Managed detection service responding 24/7

Typical evidence

- Monitoring scope and baselines
- Alert records and triage
- Service reports from the provider

8.16 Two perspectives and common difficulties

Implementer's view

- Define normal before hunting abnormal
- Ensure someone responds to alerts
- Tune continuously

Auditor's view

- What is monitored, and who responds?
- How are false positives managed?
- Sample an alert: was it assessed?

Common difficulties

- Tools without a response process
- Alert fatigue
- No baseline

Connections: 8.15 logging; 5.25 event assessment; 5.7 threat intelligence; 8.12 data leakage prevention; 8.20 network security.

MSM ACADEMY

S3.5.17 · A.8 TECHNOLOGICAL CONTROLS

A.8.17 Clock synchronization

Annex A control

8.17

S3.5.17 · CONTROL 8.17

8.17 Clock synchronization

What the control asks

Synchronize the clocks of information processing systems used by the organization to approved time sources.

Purpose

Enable correlation and analysis of security-related events and other recorded data, and support investigations.

ISO/IEC 27002 attributes

Control type
Detective

Security properties
Integrity

Cybersecurity concepts
Protect · Detect

Operational capabilities
Information security event management

Security domains
Protection · Defence

8.17 What it means and how it is done

- All systems use a common, reliable time reference.
- Usually via network time protocol to internal and trusted external sources.
- Without it, event timelines across systems cannot be reconstructed.
- Time zones handled consistently in logs.
- Cloud services’ time sources considered.

8.17 In practice

Bank

The situation

Firewall logs are 11 minutes behind server logs; an investigation cannot sequence events

Applying the control

- Internal time servers synced to two trusted sources
- All devices configured to use them
- Monitoring alerts on time drift

Typical evidence

- Time synchronization standard
- Device configuration
- Drift monitoring

8.17 Two perspectives and common difficulties

Implementer's view

- Define approved time sources
- Configure every system
- Monitor drift

Auditor's view

- Do log timestamps agree across systems?
- Which sources are used?
- Is drift monitored?

Common difficulties

- Devices using default or no time source
- Inconsistent time zones
- Drift unnoticed

Connections: 8.15 logging; 8.16 monitoring; 5.28 evidence.

MSM ACADEMY

S3.5.18 · A.8 TECHNOLOGICAL CONTROLS

A.8.18 Use of privileged utility programs

Annex A control

8.18

S3.5.18 · CONTROL 8.18

8.18 Use of privileged utility programs

What the control asks

Restrict and tightly control the use of utility programs that can be capable of overriding system and application controls.

Purpose

Ensure the use of utility programs does not harm system and application information security controls.

ISO/IEC 27002 attributes

Control type

Preventive

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Protect

Operational capabilities

System and network security · Secure configuration · Application security

Security domains

Protection

8.18 What it means and how it is done

- Examples: disk editors, password recovery tools, debugging and network tools.
- Use limited to a few trusted, authorized people.
- Utilities separated from application software; removed if unnecessary.
- Use logged and authorized per occasion where possible.
- Not available to users of systems with segregation requirements.

8.18 In practice

Manufacturing

The situation

A database editing tool on a production server lets operators change batch records directly

Applying the control

- Tool removed from production
- Available only on an admin workstation, with approval per use
- Use logged and reviewed

Typical evidence

- List of controlled utilities
- Authorization records
- Usage logs

8.18 Two perspectives and common difficulties

Implementer's view

- Inventory powerful utilities
- Remove where not needed
- Authorize and log use

Auditor's view

- Which utilities can bypass controls?
- Who can use them?
- Is use logged?

Common difficulties

- Utilities installed everywhere by default
- Unlogged use
- Ordinary users with access

Connections: 8.2 privileged access; 8.19 software installation; 5.3 segregation; 8.15 logging.

MSM ACADEMY

S3.5.19 · A.8 TECHNOLOGICAL CONTROLS

A.8.19 Installation of software on operational systems

8.19

Annex A control

S3.5.19 · CONTROL 8.19

8.19 Installation of software on operational systems

What the control asks

Implement procedures and measures to securely manage software installation on operational systems.

Purpose

Ensure the integrity of operational systems and prevent exploitation of technical vulnerabilities.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Secure configuration · Application security

Security domains
Protection

8.19 What it means and how it is done

- Only authorized people install software, following change management.
- Only approved, tested and supported software is installed.
- Users cannot install software freely where risk requires it.
- Rollback plans and previous versions kept.
- Software kept up to date and removed when unsupported.

8.19 In practice

Office

The situation

Staff install free tools from the internet; one contains malware

Applying the control

- Users cannot install software
- Approved catalogue with self-service install
- New software requests assessed by IT

Typical evidence

- Software installation policy
- Approved software catalogue
- Installation logs and requests

8.19 Two perspectives and common difficulties

Implementer's view

- Restrict installation rights
- Offer an approved catalogue
- Remove unsupported software

Auditor's view

- Can users install software?
- Is installed software approved?
- Is unsupported software present?

Common difficulties

- Free installation by users
- Unsupported software in production
- No rollback plan

Connections: 8.7 malware; 8.8 vulnerabilities; 8.32 change management; 5.32 intellectual property; 8.1 endpoints.

MSM ACADEMY

S3.5.20 · A.8 TECHNOLOGICAL CONTROLS

A.8.20 Networks security

Annex A control

8.20

S3.5.20 · CONTROL 8.20

8.20 Networks security

What the control asks

Secure, manage and control networks and network devices to protect information in systems and applications.

Purpose

Protect information in networks and its supporting information processing facilities from compromise via the network.

ISO/IEC 27002 attributes

Control type

Preventive · Detective

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Protect · Detect

Operational capabilities

System and network security

Security domains

Protection

8.20 What it means

- Network devices are managed securely: configuration, admin access, updates.
- Network documentation is current: diagrams, devices, connections.
- Traffic is controlled: firewalls, filtering, encryption.
- Wireless and remote connections are secured.

8.20 Implementation guidance (1 of 2)

- Assign responsibility for network management, separate from system operations where appropriate.
- Maintain current network documentation.
- Harden network devices; restrict and log admin access.

8.20 Implementation guidance (2 of 2)

- Control traffic with firewalls and filtering; deny by default.
- Encrypt sensitive traffic, especially over public networks.
- Authenticate devices and systems connecting to the network.
- Monitor the network (8.16); disable unused ports and services.

8.20 In practice

Factory

The situation

Office and production networks are flat; a visitor plugs a laptop into a meeting room port

Applying the control

- Network access control on wired ports
- Firewall rules reviewed; default deny
- Network diagrams updated and kept current

Typical evidence

- Network diagrams
- Firewall rule reviews
- Device configuration and access logs

8.20 Two perspectives and common difficulties

Implementer's view

- Document and harden the network
- Deny by default
- Control device connections

Auditor's view

- Are diagrams current?
- When were firewall rules last reviewed?
- Who can administer network devices?

Common difficulties

- Outdated diagrams
- Permissive firewall rules
- Open network ports

Connections: 8.21 network services; 8.22 segregation; 8.16 monitoring; 8.9 configuration; 8.24 cryptography.

MSM ACADEMY

S3.5.21 · A.8 TECHNOLOGICAL CONTROLS

A.8.21 Security of network services

Annex A control

8.21

S3.5.21 · CONTROL 8.21

8.21 Security of network services

What the control asks

Identify, implement and monitor security mechanisms, service levels and service requirements of network services.

Purpose

Ensure security in the use of network services.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
System and network security

Security domains
Protection

8.21 What it means and how it is done

- Network services: internet connectivity, VPNs, managed firewalls, private links.
- Security features and service levels agreed with providers.
- Provider’s ability to deliver securely is assessed and monitored.
- Rules on which services may be used, by whom.
- Monitoring of provider performance.

8.21 In practice

Retail chain

The situation

Stores connect through a managed network service with no security terms

Applying the control

- Security requirements and SLAs added to the contract
- Monthly provider reports reviewed
- Approved list of network services

Typical evidence

- Network service agreements
- Provider performance reports
- Approved services list

8.21 Two perspectives and common difficulties

Implementer's view

- Define security requirements for each service
- Agree them contractually
- Monitor provider performance

Auditor's view

- Are security requirements defined for network services?
- Is the provider monitored?
- Which services are approved?

Common difficulties

- Contracts without security terms
- No monitoring of providers
- Unapproved services in use

Connections: 8.20 network security; 5.19–5.22 supplier controls; 8.14 redundancy.

MSM ACADEMY

S3.5.22 · A.8 TECHNOLOGICAL CONTROLS

A.8.22 Segregation of networks

Annex A control

8.22

S3.5.22 · CONTROL 8.22

8.22 Segregation of networks

What the control asks

Segregate groups of information services, users and information systems in the organization’s networks.

Purpose

Split the network in security boundaries and control traffic between them based on business needs.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
System and network security

Security domains
Protection

8.22 What it means and how it is done

- Network divided into domains by trust level, function or sensitivity.
- Separation by VLANs, firewalls, physical separation or cloud network controls.
- Traffic between domains allowed only as needed.
- Guest and wireless networks separated from internal ones.
- Limits the spread of an attack.

8.22 In practice

Hospital

The situation

Medical devices, staff laptops and guest Wi-Fi share one network

Applying the control

- Separate networks for medical devices, staff and guests
- Firewall rules allow only required flows
- Guest Wi-Fi isolated from internal systems

Typical evidence

- Network segmentation design
- Firewall rules between segments
- Test results showing isolation

8.22 Two perspectives and common difficulties

Implementer's view

- Segment by trust and function
- Allow only needed flows
- Test the isolation

Auditor's view

- Is the network segmented?
- Are inter-segment rules justified?
- Is guest access isolated?

Common difficulties

- Flat networks
- Overly permissive inter-segment rules
- Guest Wi-Fi reaching internal systems

Connections: 8.20 network security; 8.21 network services; 8.31 separation of environments; 8.16 monitoring.

MSM ACADEMY

S3.5.23 · A.8 TECHNOLOGICAL CONTROLS

A.8.23 Web filtering

Annex A control · New in 2022

8.23

S3.5.23 · CONTROL 8.23

8.23 Web filtering

NEW IN 2022

What the control asks

Manage access to external websites to reduce exposure to malicious content.

Purpose

Protect systems from being compromised by malware and prevent access to unauthorized web resources.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
System and network security

Security domains
Protection

8.23 What it means and how it is done

- Block known malicious sites, phishing sites and risky categories.
- Rules based on risk and acceptable use policy.
- Applies to remote users too, not only on the office network.
- Users told what is blocked and why; exceptions process.
- Rules updated with threat intelligence.

8.23 In practice

Law firm

The situation

- Lawyers working from home bypass the office proxy
- A phishing site steals credentials

Applying the control

- Cloud-based web filtering on all devices, wherever they are
- Malicious and newly registered domains blocked
- Exception requests reviewed by IT

Typical evidence

- Web filtering policy and categories
- Block logs
- Exception records

8.23 Two perspectives and common difficulties

Implementer's view

- Filter on and off the network
- Block by threat category
- Run an exceptions process

Auditor's view

- Are remote users filtered?
- Which categories are blocked?
- Are exceptions controlled?

Common difficulties

- Filtering only in the office
- Outdated block lists
- Unmanaged exceptions

Connections: 8.7 malware; 5.7 threat intelligence; 5.10 acceptable use; 6.7 remote working.

Lesson 3.12 recap

- 8.15–8.17: logs protected and analysed; monitoring with a response; synchronized clocks
- 8.18–8.19: powerful utilities and software installation controlled
- 8.20–8.22: networks secured, services agreed, segments separated
- 8.23: web access filtered, wherever users are

Check your understanding

A company collects all logs centrally, but nobody reviews them and no alerts are configured.

A 8.15 and 8.16 are met: logs are collected

B A gap: logs must be analysed and monitoring must detect anomalies

C Only 8.17 clock synchronization matters

D Acceptable if logs are kept for a year

Check your understanding

A company collects all logs centrally, but nobody reviews them and no alerts are configured.

A. 8.15 and 8.16 are met: logs are collected

B. A gap: logs must be analysed and monitoring must detect anomalies

C. Only 8.17 clock synchronization matters

D. Acceptable if logs are kept for a year

Answer: B

8.15 requires logs to be analysed, and 8.16 requires monitoring for anomalous behaviour. Collection alone detects nothing.

MSM ACADEMY

SECTION 3 · LESSON 3.13

A.8 Cryptography and secure development

3.13

Controls 8.24–8.31: cryptography, the secure development life cycle, requirements, architecture, coding, testing, outsourcing and environments.

MSM ACADEMY

S3.5.24 · A.8 TECHNOLOGICAL CONTROLS

A.8.24 Use of cryptography

Annex A control

8.24

S3.5.24 · CONTROL 8.24

8.24 Use of cryptography

What the control asks

Define and implement rules for the effective use of cryptography, including cryptographic key management.

Purpose

Use cryptography properly and effectively to protect the confidentiality, authenticity or integrity of information, within the legal and contractual rules that apply to it.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Secure configuration

Security domains
Protection

8.24 What it means

- A topic-specific policy says when and how to use cryptography.
- Algorithms and key lengths follow current recognized standards.
- Key management covers the whole key life cycle.
- Legal restrictions on cryptography are respected (5.31).

8.24 Implementation guidance (1 of 2)

- Define where encryption is required: at rest, in transit, backups, removable media.
- Approve algorithms, protocols and key lengths; review as standards change.
- Consider the impact on inspection tools (e.g. malware scanning of encrypted content).

8.24 Implementation guidance (2 of 2)

- Key management: generation, storage, distribution, rotation, revocation, recovery, destruction.
- Protect keys with hardware security modules or key vaults where appropriate.
- Separate key custodians from data administrators.
- Plan for key compromise and certificate expiry.

8.24 In practice

Fintech

The situation

- Encryption keys stored in the same database as the encrypted data
- A certificate expires and takes the app offline

Applying the control

- Keys moved to a managed key vault with access control
- Certificate inventory with expiry alerts
- Approved algorithms list reviewed yearly

Typical evidence

- Cryptography policy
- Key management procedures and vault logs
- Certificate inventory

8.24 Two perspectives and common difficulties

Implementer's view

- Define where encryption is required
- Manage keys separately from data
- Track certificates and algorithms

Auditor's view

- Where is encryption required, and is it applied?
- Where are keys stored, and who can access them?
- Are algorithms current?

Common difficulties

- Keys stored with the data
- Outdated algorithms
- Expired certificates

Connections: 5.31 legal requirements; 5.17 authentication information; 8.5 secure authentication; 8.10 deletion (crypto-erasure); 5.14 transfer.

MSM ACADEMY

S3.5.25 · A.8 TECHNOLOGICAL CONTROLS

A.8.25 Secure development life cycle

8.25

Annex A control

S3.5.25 · CONTROL 8.25

8.25 Secure development life cycle

What the control asks

Establish and apply rules for the secure development of software and systems.

Purpose

Ensure information security is designed and implemented within the secure development life cycle of software and systems.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Application security · System and network security

Security domains
Protection

8.25 What it means

- Security at every stage: requirements, design, coding, testing, deployment, maintenance.
- Separate environments (8.31) and protected repositories (8.4).
- Security checkpoints in the project and release process.
- Developers trained in secure development.

8.25 Implementation guidance (1 of 2)

- Define a secure development policy and life cycle.
- Include security requirements in specifications (8.26).
- Apply secure design principles (8.27).

8.25 Implementation guidance (2 of 2)

- Use secure coding guidelines (8.28) and testing (8.29).
- Protect repositories and pipelines; control versions.
- Include security in release approval.
- Train developers; apply the same rules to outsourced work (8.30).

8.25 In practice

Software

The situation

Security is checked only by an annual penetration test after release

Applying the control

- Security gates in the delivery pipeline: requirements, code scan, tests
- Threat modelling for new features
- Secure coding training for all developers

Typical evidence

- Secure development policy
- Pipeline gate results
- Training records
- Threat models

8.25 Two perspectives and common difficulties

Implementer's view

- Embed security gates in the life cycle
- Train developers
- Apply the same rules to suppliers

Auditor's view

- Where does security enter the life cycle?
- Are gates enforced?
- Are developers trained?

Common difficulties

- Security only at the end
- Gates bypassed under deadline pressure
- Outsourced work outside the rules

Connections: 8.4 source code; 8.26–8.31 development controls; 5.8 project management; 8.32 change management.

MSM ACADEMY

S3.5.26 · A.8 TECHNOLOGICAL CONTROLS

A.8.26 Application security requirements

8.26

Annex A control

S3.5.26 · CONTROL 8.26

8.26 Application security requirements

What the control asks

Identify, specify and approve information security requirements when developing or acquiring applications.

Purpose

Ensure all information security requirements are identified and addressed when developing or acquiring applications.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Application security · System and network security

Security domains
Protection · Defence

8.26 What it means

- Requirements come from risk, classification, legal and business needs.
- Cover authentication, access, logging, data protection, input validation.
- Specific needs for transactional and online services: integrity, non-repudiation.
- Requirements are approved and later tested.

8.26 Implementation guidance

- Derive requirements from risk assessment and classification.
- Specify authentication, authorization, logging, encryption, validation.
- For purchased software, include requirements in selection and contracts.
- Approve requirements formally; trace them through design and testing.

8.26 In practice

Public sector

The situation

A benefits agency buys a case management system without security criteria

Applying the control

- Security requirements added to the tender
- Vendors scored on MFA, logging and data protection
- Requirements tested at acceptance

Typical evidence

- Approved requirements
- Tender scoring
- Acceptance test results

8.26 Two perspectives and common difficulties

Implementer's view

- Derive requirements from risk
- Put them into contracts for bought software
- Trace requirements to tests

Auditor's view

- Were security requirements specified and approved?
- Were they tested?
- Did purchases include them?

Common difficulties

- Generic requirements
- Purchased software chosen on features only
- Requirements never tested

Connections: 8.25 secure development; 8.29 testing; 5.8 projects; 5.23 cloud; 8.27 architecture.

MSM ACADEMY

S3.5.27 · A.8 TECHNOLOGICAL CONTROLS

A.8.27 Secure system architecture and engineering principles

8.27

Annex A control

S3.5.27 · CONTROL 8.27

8.27 Secure system architecture and engineering principles

What the control asks

Establish, document, maintain and apply principles for engineering secure systems to any information system development activities.

Purpose

Ensure information systems are securely designed, implemented and operated within the development life cycle.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Application security · System and network security

Security domains
Protection

8.27 What it means

- Security principles guide architecture across all layers.
- Examples: defence in depth, least privilege, secure by default, fail securely, zero trust.
- Principles apply to in-house and outsourced development.
- Principles are reviewed as threats evolve.

8.27 Implementation guidance

- Document architecture principles and patterns.
- Apply threat modelling to designs.
- Review designs against principles before build.
- Include principles in supplier requirements.
- Update principles with new threats and technology.

8.27 In practice

Fintech

The situation

A new payment API is designed with internal services trusting each other implicitly

Applying the control

- Threat model reveals lateral movement risk
- Zero-trust design: authenticated service-to-service calls
- Design review signed off against principles

Typical evidence

- Architecture principles
- Threat models
- Design review records

8.27 Two perspectives and common difficulties

Implementer's view

- Document principles
- Threat-model designs
- Review before build

Auditor's view

- Are principles documented and used?
- Sample a design: was it reviewed?
- Do suppliers follow them?

Common difficulties

- Principles on paper only
- No design review
- Implicit trust between components

Connections: 8.25 secure development; 8.26 requirements; 8.28 coding; 8.22 segregation; 5.8 projects.

MSM ACADEMY

S3.5.28 · A.8 TECHNOLOGICAL CONTROLS

A.8.28 Secure coding

Annex A control · New in 2022



S3.5.28 · CONTROL 8.28

8.28 Secure coding

NEW IN 2022

What the control asks

Apply secure coding principles to software development.

Purpose

Ensure software is written securely, thereby reducing the number of potential information security vulnerabilities in the software.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Application security · System and network security

Security domains
Protection

8.28 What it means

- Covers planning, during coding, review and maintenance.
- Guidance: validate input, encode output, handle errors safely, avoid hard-coded secrets.
- Use of vetted libraries; manage third-party and open-source components.
- Tools: static analysis, dependency scanning, code review.

8.28 Implementation guidance (1 of 2)

- Adopt secure coding standards per language, based on recognized guidance.
- Train developers; include known vulnerability types (e.g. injection, broken access control).
- Manage dependencies: inventory, vetting, updates.

8.28 Implementation guidance (2 of 2)

- Use static analysis and dependency scanning in the pipeline.
- Peer-review code for security.
- Protect against tampering in build and release.
- Fix vulnerabilities found after release quickly (link to 8.8).

8.28 In practice

Web agency

The situation

A client site is defaced through an injection flaw in a form

Applying the control

- Secure coding standard for the agency’s languages
- Static analysis and dependency scanning on every build
- Training on injection and access control flaws

Typical evidence

- Secure coding standard
- Scan reports and fixes
- Code review records
- Training records

8.28 Two perspectives and common difficulties

Implementer's view

- Adopt standards and train
- Automate scanning
- Manage dependencies

Auditor's view

- Is there a secure coding standard?
- Are scans run and findings fixed?
- Are dependencies managed?

Common difficulties

- No standard
- Scan results ignored
- Outdated libraries

Connections: 8.25 life cycle; 8.27 architecture; 8.29 testing; 8.4 source code; 8.8 vulnerabilities; 5.21 supply chain.

MSM ACADEMY

S3.5.29 · A.8 TECHNOLOGICAL CONTROLS

A.8.29 Security testing in development and acceptance

8.29

Annex A control

S3.5.29 · CONTROL 8.29

8.29 Security testing in development and acceptance

What the control asks

Define and implement security testing processes in the development life cycle.

Purpose

Validate if information security requirements are met when applications or code are deployed to the production environment.

ISO/IEC 27002 attributes

Control type

Preventive

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Identify

Operational capabilities

Application security · Information security assurance · System and network security

Security domains

Protection

8.29 What it means

- Tests are planned against the security requirements (8.26).
- Methods: code review, scanning, vulnerability tests, penetration tests.
- Acceptance testing includes security before production.
- Tests in an environment like production (8.31), with protected test data (8.33).

8.29 Implementation guidance

- Plan tests from requirements; define pass criteria.
- Combine automated scanning with manual and penetration testing by risk.
- Include security in acceptance testing for new and changed systems.
- Test purchased and outsourced software too.
- Record results; fix and retest before release.

8.29 In practice

Bank

The situation

A mobile banking release goes live with an untested session-handling change

Applying the control

- Security test plan tied to requirements
- Automated tests on every build; penetration test before major releases
- Release blocked until critical findings fixed

Typical evidence

- Test plans and results
- Penetration test reports
- Release approvals showing security sign-off

8.29 Two perspectives and common difficulties

Implementer's view

- Test against requirements
- Scale testing to risk
- Block release on critical findings

Auditor's view

- Were security tests run for recent releases?
- Were findings fixed before release?
- Are bought systems tested?

Common difficulties

- Testing only functionality
- Findings deferred indefinitely
- Purchased software assumed secure

Connections: 8.26 requirements; 8.25 life cycle; 8.31 environments; 8.33 test information; 8.32 change management.

MSM ACADEMY

S3.5.30 · A.8 TECHNOLOGICAL CONTROLS

A.8.30 Outsourced development

8.30

Annex A control

S3.5.30 · CONTROL 8.30

8.30 Outsourced development

What the control asks

Direct, monitor and review the activities related to outsourced system development.

Purpose

Ensure information security measures required by the organization are implemented in outsourced system development.

ISO/IEC 27002 attributes

Control type

Preventive · Detective

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Identify · Protect · Detect

Operational capabilities

System and network security · Application security · Supplier relationships security

Security domains

Governance and Ecosystem · Protection

8.30 What it means

- The organization stays accountable for outsourced development.
- Requirements are set in contracts: secure development, testing, IP, escrow.
- Development is monitored and deliverables are tested.
- Applies when development is contracted out to other organizations.

8.30 Implementation guidance

- Contract: secure development requirements, testing, licensing, IP ownership.
- Require evidence of supplier’s secure practices and testing.
- Retain rights to audit; agree escrow where continuity needs it.
- Test deliverables, including for malicious content.
- Monitor progress and quality against requirements.

8.30 In practice

Logistics

The situation

A logistics company outsources its customer portal to a development agency

Applying the control

- Contract requires secure coding standard and test evidence
- Independent penetration test before acceptance
- Code escrow and IP clauses

Typical evidence

- Development contract
- Supplier test evidence
- Acceptance test and penetration test reports

8.30 Two perspectives and common difficulties

Implementer's view

- Contract the security requirements
- Test deliverables independently
- Monitor the supplier

Auditor's view

- Do contracts set security requirements?
- Were deliverables tested?
- Who owns the code?

Common difficulties

- Accepting deliverables untested
- Unclear IP ownership
- No monitoring of the supplier

Connections: 5.19–5.22 suppliers; 8.25–8.29 development controls; 5.32 intellectual property.

MSM ACADEMY

S3.5.31 · A.8 TECHNOLOGICAL CONTROLS

A.8.31 Separation of development, test and production environments

8.31

Annex A control

S3.5.31 · CONTROL 8.31

8.31 Separation of development, test and production environments

What the control asks

Separate and secure development, testing and production environments.

Purpose

Protect the production environment and data from compromise by development and test activities.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Application security · System and network security

Security domains
Protection

8.31 What it means

- Separate environments, logically or physically.
- Rules for moving software from development to production.
- Developers’ access to production restricted.
- Production data not used in test unless protected (8.33).

8.31 Implementation guidance

- Define and separate environments; label them clearly.
- Control promotion between environments through change management.
- Restrict production access; log any emergency access.
- Keep development tools out of production.
- Protect test environments too: they often hold sensitive copies.

8.31 In practice

SaaS

The situation

Developers deploy fixes directly to production servers

Applying the control

- Separate cloud accounts for dev, test and production
- Deployment only through the pipeline
- Production access via just-in-time approval

Typical evidence

- Environment architecture
- Pipeline deployment records
- Production access logs

8.31 Two perspectives and common difficulties

Implementer's view

- Separate environments clearly
- Deploy only through controlled promotion
- Restrict production access

Auditor's view

- Are environments separated?
- Can developers change production directly?
- Is production data in test?

Common difficulties

- Direct changes in production
- Shared credentials across environments
- Unprotected test environments

Connections: 8.32 change management; 8.33 test information; 8.4 source code; 8.22 segregation; 8.2 privileged access.

Lesson 3.13 recap

- 8.24: cryptography rules and key management
- 8.25–8.27: secure life cycle, requirements and architecture
- 8.28–8.29: secure coding and security testing
- 8.30–8.31: outsourced development directed; environments separated

Check your understanding

A bought SaaS application passes functional acceptance. No security requirements were specified or tested before purchase.

A Acceptable: 8.26 applies only to in-house development

B A gap: 8.26 covers acquired applications, and 8.29 testing should validate them

C Only a supplier issue under 5.19

D Acceptable if the vendor is certified

Check your understanding

A bought SaaS application passes functional acceptance. No security requirements were specified or tested before purchase.

A. Acceptable: 8.26 applies only to in-house development

B. A gap: 8.26 covers acquired applications, and 8.29 testing should validate them

C. Only a supplier issue under 5.19

D. Acceptable if the vendor is certified

Answer: B

8.26 covers developing or acquiring applications; 8.29 validates the requirements. Buying does not remove the need.

MSM ACADEMY

SECTION 3 · LESSON 3.14

A.8 Change, test data and audit protection

3.14

Controls 8.32–8.34: change management, test information, and protecting systems during audit testing.

MSM ACADEMY

S3.5.32 · A.8 TECHNOLOGICAL CONTROLS

A.8.32 Change management

Annex A control

8.32

S3.5.32 · CONTROL 8.32

8.32 Change management

What the control asks

Subject changes to information processing facilities and information systems to change management procedures.

Purpose

Preserve information security when executing changes.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity · Availability

Cybersecurity concepts
Protect

Operational capabilities
Application security · System and network security

Security domains
Protection

8.32 What it means

- All changes planned, assessed, authorized, tested and recorded.
- Impact assessment includes security impact.
- Emergency changes follow a defined fast path and are reviewed afterwards.
- Documentation and procedures updated after change.

8.32 Implementation guidance (1 of 2)

- Define change types: standard, normal, emergency.
- Record each change with its owner, reason and impact.
- Assess security impact and dependencies.

8.32 Implementation guidance (2 of 2)

- Authorize by the right level; separate requester and approver.
- Test before production; plan rollback.
- Communicate to affected people.
- Review changes after implementation, especially emergencies.

8.32 In practice

Retail

The situation

A firewall rule change made on a Friday evening exposes an internal database

Applying the control

- Change request with security impact assessment
- Peer review and approval before implementation
- Post-change verification and rollback plan

Typical evidence

- Change register with approvals
- Security impact assessments
- Post-implementation reviews

8.32 Two perspectives and common difficulties

Implementer's view

- Include security in every impact assessment
- Separate request and approval
- Review emergency changes

Auditor's view

- Sample changes: assessed, approved, tested?
- Is security impact considered?
- How are emergency changes controlled?

Common difficulties

- Changes made outside the process
- Security impact never assessed
- Emergency route used routinely

Connections: 8.9 configuration; 8.31 environments; 8.29 testing; 5.3 segregation; 8.19 software installation; ISO/IEC 27001 6.3 and 8.1.

MSM ACADEMY

S3.5.33 · A.8 TECHNOLOGICAL CONTROLS

A.8.33 Test information

Annex A control

8.33

S3.5.33 · CONTROL 8.33

8.33 Test information

What the control asks

Appropriately select, protect and manage test information.

Purpose

Ensure relevance of testing and protection of operational information used for testing.

ISO/IEC 27002 attributes

Control type
Preventive

Security properties
Confidentiality · Integrity

Cybersecurity concepts
Protect

Operational capabilities
Information protection

Security domains
Protection

8.33 What it means and how it is done

- Prefer synthetic or masked data for testing.
- If production data is used: authorization, same protection as production, deletion after use.
- Copying production data into test is logged.
- Test environments protected like the data they hold.
- Applies to all test types, including user acceptance.

8.33 In practice

Insurance

The situation

A full copy of the policy database sits in a test environment open to contractors

Applying the control

- Synthetic data for most tests
- Masked extracts only when realistic data is essential
- Copies authorized, logged and deleted after use

Typical evidence

- Test data procedure
- Authorizations and copy logs
- Deletion records

8.33 Two perspectives and common difficulties

Implementer's view

- Prefer synthetic or masked data
- Authorize and log production copies
- Delete after use

Auditor's view

- What data is in test environments?
- Were production copies authorized?
- Are they deleted?

Common difficulties

- Production data copied routinely
- Test environments weakly protected
- Copies never deleted

Connections: 8.11 data masking; 8.31 environments; 8.29 testing; 5.34 privacy; 8.10 deletion.

MSM ACADEMY

S3.5.34 · A.8 TECHNOLOGICAL CONTROLS

A.8.34 Protection of information systems during audit testing

8.34

Annex A control

S3.5.34 · CONTROL 8.34

8.34 Protection of information systems during audit testing

What the control asks

Plan and agree audit tests and other assurance activities involving assessment of operational systems between the tester and appropriate management.

Purpose

Minimize the impact of audit and other assurance activities on operational systems and business processes.

ISO/IEC 27002 attributes

Control type

Preventive

Security properties

Confidentiality · Integrity · Availability

Cybersecurity concepts

Protect

Operational capabilities

System and network security · Information protection

Security domains

Governance and Ecosystem · Protection

8.34 What it means and how it is done

- Scope and timing of technical tests agreed in advance.
- Read-only access where possible; copies analysed off-line.
- Tests that could affect availability done out of hours.
- Access for testers monitored, logged and removed afterwards.
- Applies to internal, external and penetration testers.

8.34 In practice

Bank

The situation

A penetration test scan crashes a core banking system during business hours

Applying the control

- Rules of engagement agreed with management
- High-impact tests scheduled at night with operations on standby
- Tester accounts time-limited and logged

Typical evidence

- Signed rules of engagement
- Test schedules
- Tester access logs and removal

8.34 Two perspectives and common difficulties

Implementer's view

- Agree scope and timing in writing
- Limit tester access
- Schedule risky tests carefully

Auditor's view

- Were tests agreed with management?
- Was tester access controlled and removed?
- Any impact incidents?

Common difficulties

- Tests started without agreement
- Permanent tester accounts
- Production disrupted by testing

Connections: 5.35 independent review; ISO/IEC 27001 9.2 internal audit; 8.29 security testing; 8.2 privileged access.

Lesson 3.14 recap

- 8.32: every change assessed for security, approved, tested and recorded
- 8.33: test data synthetic or masked; production copies controlled
- 8.34: audit and assurance tests agreed and controlled

Check your understanding

An urgent production fix is applied without approval “because it was an emergency”. Nobody reviews it afterwards.

A Acceptable: emergencies are outside change management

B A gap against 8.32: emergency changes need a defined route and later review

C Only a 8.31 environment issue

D Acceptable if the fix worked

Check your understanding

An urgent production fix is applied without approval “because it was an emergency”. Nobody reviews it afterwards.

A. Acceptable: emergencies are outside change management

B. A gap against 8.32: emergency changes need a defined route and later review

C. Only a 8.31 environment issue

D. Acceptable if the fix worked

Answer: B

8.32 expects emergency changes to follow a defined fast path and to be reviewed afterwards, not to bypass control entirely.

MSM ACADEMY

SECTION 3 · LESSON 3.15

Section close

The 93 controls in one view.



LESSON 3.15

The 93 controls in one view

Theme	Controls	What they achieve together
A.5 Organizational	5.1–5.37	Direction, ownership, access, suppliers, incidents, continuity and compliance
A.6 People	6.1–6.8	Trustworthy, aware and accountable people, wherever they work
A.7 Physical	7.1–7.14	Protected sites, equipment and media, from entry to disposal
A.8 Technological	8.1–8.34	Secure endpoints, access, operations, networks, development and change

LESSON 3.15

Using the controls well

Four lasting points

1. Controls are selected by risk treatment, then checked against Annex A (6.1.3).
2. Each control works with others: access depends on identity, monitoring on logging, recovery on backup.
3. Evidence shows a control operates, not just that it exists.
4. ISO/IEC 27002 guidance helps implementation; only ISO/IEC 27001 contains requirements.

SECTION 3 COMPLETE

Next: Section 4

Implementation methodology: planning and running an ISMS implementation.

